

INFOASSURE LIMITED

Cybersecurity Graduate Internship Programme Capstone Engagement

PayNova Financial Services Ltd

Cybersecurity Assessment Report

*End-to-End Risk Assessment, Vulnerability Management & Compliance
Roadmap*

Client	PayNova Financial Services Ltd
Prepared by	Team Vanguard — Infoassure Limited
Report date	28 September 2026
Assessment window	17-26 September 2026
Classification	Confidential

Table of Contents

Table of Contents.....	2
Document Control.....	6
Version History.....	6
Distribution.....	6
Executive Summary.....	7
1. Assessment Scope.....	9
1.1 Assessment Objective	9
1.2 In-Scope Assets.....	9
1.3 Network Scope	9
1.4 Assessment Perspective.....	10
1.5 Rules of Engagement.....	10
2. Asset Inventory	11
2.1 DMZ	11
2.2 Payment Network.....	11
2.3 Corporate Network.....	11
2.4 Multi-Homed Analyst Toolbox	12
3. Network Reconnaissance Findings.....	13
3.1 DMZ Network — 172.20.0.0/24.....	13
3.1.1 172.20.0.10 — PayNova Portal	13
3.1.2 172.20.0.20 — PayNova Web Application	14
3.1.3 172.20.0.99 — Analyst Toolbox (DMZ NIC).....	15
3.2 Payment Network — 172.21.0.0/24	15
3.2.1 172.21.0.10 — PayNova Database.....	15
3.2.2 172.21.0.11 — Card Scheme API.....	16
3.2.3 172.21.0.12 — Credit Bureau API	17
3.2.4 172.21.0.99 — Analyst Toolbox (Payment NIC)	18

3.3 Corporate Network — 172.22.0.0/24	18
3.3.1 172.22.0.10 — PAYNOVA-DC	18
3.3.2 172.22.0.99 — Analyst Toolbox (Corporate NIC)	19
3.4 Initial Attack-Surface Summary	20
4. Active Directory & Identity Security	21
4.1 Service Enumeration.....	21
4.2 Detailed Findings.....	22
4.2.1 Finding — LDAP RootDSE Information Disclosure	22
4.2.2 Finding — Anonymous SMB Share Enumeration	24
4.2.3 Finding — Weak Active Directory Password and Account Lockout Policy.....	25
4.2.4 Observation — Administrator Group Memberships.....	27
4.3 Positive Controls Observed	27
5. Network Segmentation Findings	28
5.1 Finding — Excessive DMZ-to-Payment Network Access.....	28
5.2 Finding — DMZ-to-Corporate Network Segmentation.....	29
5.3 Finding — Payment-to-AD Segmentation.....	30
5.4 Note — Toolbox Network Reachability.....	31
5.5 Questions Asked During Testing.....	31
Q1 — Can the DMZ reach the Payment network?	31
Q2 — Can the DMZ reach the Corporate network?.....	32
Q3 — Can Payment services reach AD?	32
Q4 — Can the toolbox reach everything?.....	32
Section conclusion	32
6. Web Application Testing Findings.....	33
6.1 Unauthenticated Exposure of Sensitive Customer Backup Data.....	33
6.2 SQL Injection — Authentication Bypass to Administrator Account.....	36
6.3 Broken Object-Level Authorization — Unauthorised Basket Access.....	39

6.4 Broken Access Control — Unauthorised Access to Administrative Application Configuration	41
6.5 DOM-Based Cross-Site Scripting.....	43
6.6 Session Token Replay — Token Remains Valid After Logout.....	45
6.7 Server Version Information Disclosure	47
7. API Testing Findings.....	49
7.1 Unauthenticated Card Data Enumeration and Excessive Sensitive Data Exposure .	49
7.2 Debug Configuration and Sensitive Information Disclosure.....	52
8. Database Security	55
8.1 Remote MySQL Root Account with Excessive Privileges.....	55
8.2 Sensitive Payment Card Data (PAN + CVV) Stored in Database.....	58
8.3 Sensitive Customer PII Stored in Cleartext	60
8.4 Excessive Database Privileges on Application Account	62
8.5 Weak Password Hashing Algorithm (MD5).....	63
9. Negative Test Results (No Vulnerability Observed)	66
9.1 Backup File Exposure — Card Scheme API.....	66
9.2 Command Injection Source-Code Review	68
9.3 Stack Trace Disclosure.....	69
10. Summary of Findings	70
10.1 Risk-Rating Scheme (Reference)	70
10.2 Finding Counts by Severity.....	72
10.3 Consolidated Finding Register	72
11. Compliance Mapping	76
12. Remediation Roadmap	79
Appendix A. Evidence Register	83
Appendix B. Tools Used.....	87
Appendix C. Redaction Note.....	88
Appendix D. Project Deliverables Index.....	89

D.1 Reading Order.....	90
D.2 Update Cycle.....	91

Document Control

Version History

Version	Date	Author
v1.0	27 Sep 2026	Team Vanguard – Infoassure Limited

Distribution

Recipient	Role	Format
Capstone Panel	Executive review	Word document

Executive Summary

This report presents the findings of an internal cybersecurity assessment conducted against the isolated PayNova Financial Services laboratory environment. PayNova is a simulated mid-sized fintech operating card payments, mobile wallets, and micro-lending, with a hybrid on-premises architecture spanning a DMZ, a Payment network, and a Corporate/Active Directory network.

Assessment posture

Testing across the six technical phases has identified twenty-three confirmed findings across network, Active Directory, web-application, API, and database layers. Four are rated Critical, six are High, nine are Medium, and four are Low. The four Critical findings all involve unauthorised access to, or storage of, regulated payment or authentication data: the customer-facing web tier exposes a customer backup file containing PANs, CVVs, and wallet PINs via an unauthenticated directory listing; the Card Scheme API returns the full card collection to unauthenticated callers via GET /cards; the MySQL database has a remote root@'%' account with full administrative privileges reachable from the Payment network; and the cards table itself stores CVV values in cleartext, a direct PCI DSS v4.0.1 Requirement 3.3 violation independent of any exposure path. A further Critical finding demonstrates SQL-injection authentication bypass to an administrator account on the customer web application.

Additional High-rated findings cover: the DMZ web tier having unrestricted network-level reachability to the Payment database and both payment APIs; the Card Scheme API exposing a /debug/config endpoint that leaks environment variables and the JWT signing secret; the customer web-application backup exposure; sensitive customer PII in the customers table including MD5-format password hashes; the paynova_app application database account holding ALL PRIVILEGES on the paynova schema; and the use of MD5 for customer password storage.

Positive controls observed include enforced SMB message signing on the domain controller, effective network segmentation between the DMZ and Corporate networks and between the Payment and Corporate networks, LDAP requiring authentication for directory operations (validated with Idapsearch, revising an earlier suspected finding),

SMB anonymous authentication with correctly-denied share content access, and the restricted paynova_readonly database account holding SELECT-only privileges.

Assessment status

This is the final consolidated release covering all six technical assessment phases: network and infrastructure security (Wk 3), operating-system and Active Directory / identity security (Wk 4), web application testing against the customer portal and OWASP Juice Shop instance (Wk 7), API testing against the Card Scheme API (Wk 6/7), and database security testing against paynova-db (Wk 8). Security operations, incident monitoring, and formal penetration exploitation are covered by the companion Incident Response Plan (Wk 5) and remain the primary areas for continuous improvement.

Companion deliverables

Three companion deliverables were produced alongside this iteration of the report and should be read as an integrated set (see Appendix D for the deliverables index). The PayNova Risk Register v3 consolidates all confirmed findings into 40 tracked risks with likelihood, impact, recommended controls, residual scores, and target dates. The Privacy Impact Assessment v1.0 evaluates the personal-data processing against NDPA 2023, GDPR, and UK GDPR, and raises 15 privacy risks (PR-01 to PR-15) — six of which (PR-08 to PR-12, PR-15) have been propagated to the risk register as R-035 to R-040 in v3. The Incident Response Plan v1.0 documents the process for detecting, containing, eradicating, recovering from, and notifying about incidents, using the PN-WEB-001 backup exposure as the worked example throughout.

1. Assessment Scope

1.1 Assessment Objective

Assess the security posture of the isolated PayNova financial-services laboratory environment and identify vulnerabilities, misconfigurations, excessive network exposure, authentication weaknesses, and other security risks.

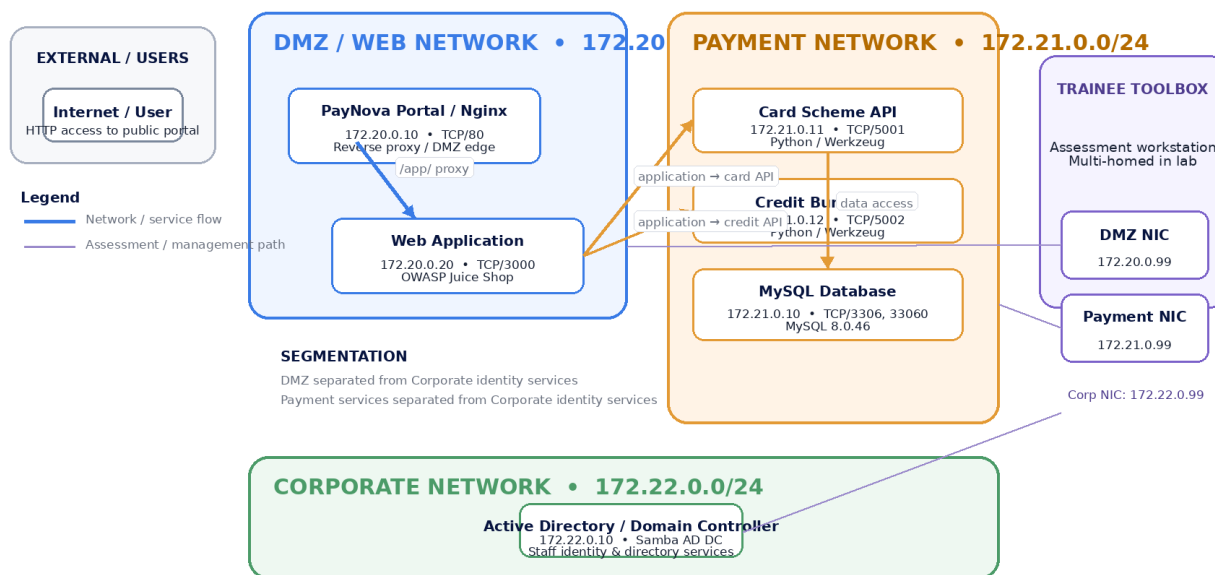
1.2 In-Scope Assets

- PayNova Web & Mobile Portal (paynova-portal)
- PayNova Customer Web Application (paynova-webapp — OWASP Juice Shop instance)
- PayNova MySQL database (paynova-db)
- PayNova Active Directory (paynova-ad / PAYNOVA-DC)
- PayNova Card Scheme API (paynova-cardscheme-api)
- PayNova Credit Bureau API (paynova-creditbureau-api)
- DMZ, Payment, and Corporate networks
- Analyst toolbox (paynova-toolbox)

1.3 Network Scope/ Network Daigram

Segment	Subnet	Purpose
DMZ	172.20.0.0/24	Public-facing / application services
Payment	172.21.0.0/24	Payment and database services
Corporate	172.22.0.0/24	Active Directory / corporate services

Technical Network Architecture — Controlled Cybersecurity Lab



1.4 Assessment Perspective

Testing was performed initially from the analyst toolbox, representing an internal security analyst / security assessment workstation. The assessment evaluated both what an authorised internal analyst can reach, and what an attacker could potentially reach after obtaining access to a particular network segment (using namespace-pinned testing from within compromised-application containers).

1.5 Rules of Engagement

- Testing is restricted to the isolated PayNova laboratory.
- No external systems will be tested.
- No real financial information is involved.
- Destructive testing will be avoided unless specifically required by the lab.
- Evidence will be collected for all significant findings.
- Findings will be validated before being classified as confirmed vulnerabilities.

2. Asset Inventory

Assessment date: 18 September 2026. Assessment environment: isolated PayNova Docker laboratory environment.

2.1 DMZ

Asset	IP Address	Ports/Services	Network
paynova-portal	172.20.0.10	TCP/8080 (nginx 1.27.5)	DMZ
paynova-webapp	172.20.0.20	TCP/3000 (OWASP Juice Shop)	DMZ
paynova-toolbox	172.20.0.99	Analyst workstation	DMZ

2.2 Payment Network

Asset	IP Address	Ports/Services	Network
paynova-db	172.21.0.10	TCP/3306 (MySQL 8.0.46)	Payment
paynova-cardscheme-api	172.21.0.11	TCP/5001 (Werkzeug/Flask)	Payment
paynova-creditbureau-api	172.21.0.12	TCP/5002 (Werkzeug/Flask)	Payment
paynova-toolbox	172.21.0.99	Analyst workstation	Payment

2.3 Corporate Network

Asset	IP Address	Ports/Services	Network
paynova-ad (PAYNOVA-DC)	172.22.0.10	DNS, Kerberos, LDAP, SMB, and related AD services (Samba 4.6.2)	Corporate
paynova-toolbox	172.22.0.99	Analyst workstation	Corporate

2.4 Multi-Homed Analyst Toolbox

The analyst toolbox is connected to all three PayNova network segments (172.20.0.99, 172.21.0.99, 172.22.0.99), providing the assessment workstation with visibility into all three segments. This is intentional for security-assessment purposes and is not itself treated as a segmentation finding.

3. Network Reconnaissance Findings

Command executed:

```
nmap -sV -sC 172.20.0.0/24 172.21.0.0/24 172.22.0.0/24
```

Purpose: identify live hosts, exposed TCP services, service versions, and security-relevant configuration information across the DMZ, Payment, and Corporate network segments.

3.1 DMZ Network — 172.20.0.0/24

3.1.1 172.20.0.10 — PayNova Portal

TCP/80 open — Nginx 1.27.5. HTTP title: PayNova Web & Mobile Portal.

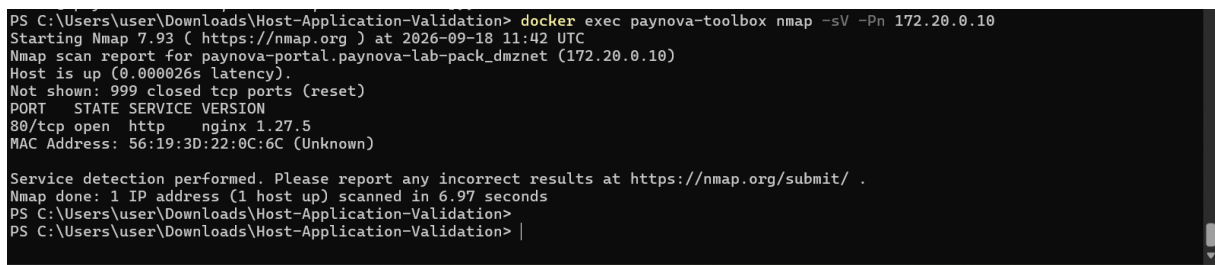
robots.txt contains:

- /backups/
- /app/administration

Nmap identified the web service as potentially using a reverse proxy.

Security relevance

The presence of /backups/ and /app/administration in robots.txt identifies potentially sensitive application paths that should be investigated for unauthorised access. This is a reconnaissance observation; the /backups/ path is validated as an exploitable finding under Section 6.1.



```
PS C:\Users\user\Downloads\Host-Application-Validation> docker exec paynova-toolbox nmap -sV -Pn 172.20.0.10
Starting Nmap 7.93 ( https://nmap.org ) at 2026-09-18 11:42 UTC
Nmap scan report for paynova-portal.paynova-lab-pack_dmznet (172.20.0.10)
Host is up (0.000026s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.27.5
MAC Address: 56:19:3D:22:0C:6C (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.97 seconds
PS C:\Users\user\Downloads\Host-Application-Validation>
PS C:\Users\user\Downloads\Host-Application-Validation>
```

Figure 1. Nmap -sV against the PayNova portal — TCP/80 open with nginx 1.27.5.

```

<!DOCTYPE HTML>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error response</title>
</head>
<body>
<h1>Error response</h1>
<p>Error code: 400</p>
<p>Message: Bad request syntax ('HELP').</p>
<p>Error code explanation: 400 - Bad request syntax or unsupported method.</p>
</body>
</html>
RTSPRequest:
<!DOCTYPE HTML>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error response</title>
</head>
<body>
<h1>Error response</h1>
<p>Error code: 400</p>
<p>Message: Bad request version ('RTSP/1.0').</p>
<p>Error code explanation: 400 - Bad request syntax or unsupported method.</p>
</body>
</html>
_
8080/tcp open  http          nginx 1.27.5
|_http-server-header: nginx/1.27.5
|_http-title: PayNova Web & Mobile Portal
|_http-robots.txt: 2 disallowed entries
|_backups/ /app/administration
|_http-open-proxy: Proxy might be redirecting requests

```

Figure 2. Nmap http-robots.txt NSE output for the PayNova portal – discloses /backups/ and /app/administration.

3.1.2 172.20.0.20 — PayNova Web Application

TCP/3000 open. Web application detected. HTTP response returned 200 OK. Application exposes HTTP headers including Access-Control-Allow-Origin: *, X-Frame-Options: SAMEORIGIN, X-Content-Type-Options: nosniff. Application response identified the application as an OWASP Juice Shop-based application.

Security relevance

The application is directly reachable on TCP/3000 within the scanned network and should be assessed for web application vulnerabilities and access-control weaknesses (see Section 6). The wildcard CORS header is carried forward as a distinct finding in Section 6.7.

```

PS C:\Users\user\Downloads\Host-Application-Validation> docker exec paynova-toolbox nmap -sV -Pn 172.20.0.20
Starting Nmap 7.93 ( https://nmap.org ) at 2026-09-18 11:49 UTC
Nmap scan report for paynova-webapp.paynova-lab-pack_dmznet (172.20.0.20)
Host is up (0.000036s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3000/tcp  open  ppp?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
_
SF-Port3000-TCP:V=7.93%I=7%D=9/18%Time=6AAD2564%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,2668,"HTTP/1.1.%x20200\x200K\r\nAccess-Control-Allow-Origin:\x
SF:20*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAMEO
SF:RIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#/jo
SF:bs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-age=0
SF:\r\nLast-Modified:\x20Wed,\x2016\x20Sep\x202026\x2021:31:30\x20GMT\r\nE
SF:Tag:\x20W/"24b1-1a0ac21c897"\r\nContent-Type:\x20text/html;\x20charse
SF:t=UTF-8\r\nContent-Length:\x209393\r\nVary:\x20Accept-Encoding\r\nDate:
SF:\x20Fri,\x2018\x20Sep\x202026\x2011:49:56\x20GMT\r\nConnection:\x20clos
SF:e\r\n\r\n<!--\n\x20\x20\x20Copyright\x20(c)\x202014-2026\x20Bjoern\x
SF:20Kimmich\x20&\x20the\x20OWASP\x20Juice\x20Shop\x20contributors.\n\x
SF:20\x20~\x20SPDX-License-Identifier:\x20MIT\n\x20\x20-->\n<!doctype\x2
SF:0html>\n<html\x20lang="en"\x20data-beasties-container>\n<head>\n\x20\
SF:x20<meta\x20charset="utf-8">\n\x20\x20<title>OWASP\x20Juice\x20Shop</
SF:title>\n\x20\x20<meta\x20name="description"\x20content="Probably\x20
SF:the\x20most\x20modern\x20and\x20sophisticated\x20insecure\x20web\x20app
SF:lication">\n\x20\x20<meta\x20name="viewport"\x20content="width=devi
SF:ce-width,\x20initial-scale=1">\n\x20\x20<link\x20rel="preconnect"\x2
SF:0href="htt">\n\x20<script>\n\x20(HTT,2F,"HTTP/1.1\x20400\x20Bad\x20Request\r\nConnecti
SF:on:\x20close\r\n\r\n")%r(NCP,2F,"HTTP/1.1\x20400\x20Bad\x20Request\r\n
SF:Connection:\x20close\r\n\r\n")%r(HTTPOptions,EA,"HTTP/1.1\x20204\x20No
SF:\x20Content\r\nAccess-Control-Allow-Origin:\x20*\r\nAccess-Control-All
SF:ow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-Contro
SF:L-Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Fri,\x2018\x20Sep

```

Figure 3. Nmap -sV against the customer web application — identifies OWASP Juice Shop, wildcard CORS, and permissive HTTP methods.

3.1.3 172.20.0.99 — Analyst Toolbox (DMZ NIC)

Host detected. Nmap reported all scanned TCP ports as closed. No exposed TCP service identified. Consistent with the toolbox operating as an assessment workstation with no listening services of its own.

3.2 Payment Network — 172.21.0.0/24

3.2.1 172.21.0.10 — PayNova Database

TCP/3306 open — MySQL 8.0.46. TLS/SSL certificate present (auto-generated: commonName=MySQL_Server_8.0.46_Auto_Generated_Server_Certificate). Authentication plugin identified as caching_sha2_password.

Security relevance

A database service is exposed on the Payment network. The auto-generated TLS certificate is a MySQL default that should be replaced with a properly-issued certificate during the database-hardening phase. Whether access is appropriately restricted to authorised application hosts is considered under the segmentation findings in Section 5.

```

PS C:\Users\user\Downloads\Host-Application-Validation> docker exec paynova-toolbox nmap -sV -Pn 172.21.0.10
Starting Nmap 7.93 ( https://nmap.org ) at 2026-09-18 12:04 UTC
Nmap scan report for paynova-db.paynova-lab-pack_paymentnet (172.21.0.10)
Host is up (0.000038s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 8.0.46
MAC Address: B6:7F:32:1D:C2:E6 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.85 seconds
PS C:\Users\user\Downloads\Host-Application-Validation>

```

Figure 4. Nmap -sV against paynova-db — TCP/3306 open, MySQL 8.0.46.

```

Help:
<!DOCTYPE HTML>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error response</title>
</head>
<body>
<h1>Error response</h1>
<p>Error code: 400</p>
<p>Message: Bad request syntax ('HELP').</p>
<p>Error code explanation: 400 - Bad request syntax or unsupported method.</p>
</body>
</html>
RTSPRequest:
<!DOCTYPE HTML>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error response</title>
</head>
<body>
<h1>Error response</h1>
<p>Error code: 400</p>
<p>Message: Bad request version ('RTSP/1.0').</p>
<p>Error code explanation: 400 - Bad request syntax or unsupported method.</p>
</body>
</html>
_
8080/tcp open  http      nginx 1.27.5
|_http-title: PayNova Web & Mobile Portal
|_http-robots.txt: 2 disallowed entries
|_backups/ /app/administration
|_http-server-header: nginx/1.27.5

```

Figure 5. Extended mysql-info NSE output — protocol, version, capability flags, caching_sha2_password authentication plugin, and the auto-generated server certificate.

3.2.2 172.21.0.11 — Card Scheme API

TCP/5001 open. Service identified as an HTTP/API service. Server response indicates Werkzeug 3.1.8 / Python 3.11.16. HTTP requests to unrecognised paths return 404 Not Found.

Security relevance

The API technology stack has been identified and is served by Werkzeug — the Flask development WSGI server, not intended for production. The API is assessed further in Section 7, where two Critical/High findings are raised against it.

```
PS C:\Users\user\Downloads\Host-Application-Validation> docker exec paynova-toolbox nmap -sV -pN 172.21.0.11
Starting Nmap 7.93 ( https://nmap.org ) at 2026-09-18 12:09 UTC
Nmap scan report for paynova-cardscheme-api.paynova-lab-pack_paymentnet (172.21.0.11)
Host is up (0.000051s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
5001/tcp  open  complex-link?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
_
SF-Port5001-TCP:V=7.93I=7%D=9/18T=6AAD29F8%P=x86_64-pc-linux-gnu%r(Ge
SF:Request,185,"HTTP/1.1\x20404\x20NOT\x20FOUND\r\nServer:\x20Werkzeug/3
SF:.\1.\8\x20Python/3.\11.\16\r\nDate:\x20Fri,\x2018\x20Sep\x202026\x2012:
SF:09:28GMT\r\nContent-Type:\x20text/html;\x20charset=utf-8\r\nContent
SF:-Length:\x20207\r\nConnection:\x20close\r\n\r\n<!doctype\x20html>\n<htm
SF:l\x20lang=en>\n<title>404\x20Not\x20Found</title>\n<h1>Not\x20Found</h1
SF:>\n<p>The\x20requested\x20URL\x20was\x20not\x20found\x20on\x20the\x20se
SF:rver.\x20If\x20you\x20entered\x20the\x20URL\x20manually\x20please\x20c
SF:heck\x20your\x20spelling\x20and\x20try\x20again\.</p>\n")%r(HTTPOptions
SF: ,185,"HTTP/1.1\x20404\x20NOT\x20FOUND\r\nServer:\x20Werkzeug/3.\1.\8\x
SF:20Python/3.\11.\16\r\nDate:\x20Fri,\x2018\x20Sep\x202026\x2012:09:28\x2
SF:0GMT\r\nContent-Type:\x20text/html;\x20charset=utf-8\r\nContent-Length:
SF:\x20207\r\nConnection:\x20close\r\n\r\n<!doctype\x20html>\n<html\x20lan
SF:g=en>\n<title>404\x20Not\x20Found</title>\n<h1>Not\x20Found</h1>\n<p>Th
SF:e\x20requested\x20URL\x20was\x20not\x20found\x20on\x20the\x20server\.\x
SF:20If\x20you\x20entered\x20the\x20URL\x20manually\x20please\x20check\x20
SF:your\x20spelling\x20and\x20try\x20again\.</p>\n")%r(RTSPRequest,16C,"<!
SF:DOCTYPE\x20HTML>\n<html\x20lang=en">\n\x20\x20\x20\x20<head>\n\x20\x
SF:20\x20\x20\x20\x20\x20\x20<meta\x20charset="utf-8">\n\x20\x20\x20\x20
SF:\x20\x20\x20\x20<title>Error\x20response</title>\n\x20\x20\x20\x20</hea
SF:d>\n\x20\x20\x20\x20\x20<body>\n\x20\x20\x20\x20\x20\x20\x20<h1>Error\x
SF:20response</h1>\n\x20\x20\x20\x20\x20\x20\x20\x20<p>Error\x20code:\x204
SF:00</p>\n\x20\x20\x20\x20\x20\x20\x20\x20<p>Message:\x20Bad\x20request\x
```

Figure 6. Nmap -sV against paynova-cardscheme-api – Werkzeug 3.1.8 / Python 3.11.16 identified in HTTP responses.

3.2.3 172.21.0.12 – Credit Bureau API

TCP/5002 open. Service identified as an HTTP/API service. Server response indicates Werkzeug 3.1.8 / Python 3.11.16. Unrecognised HTTP requests return 404 Not Found.

Security relevance

The service stack and API endpoint are exposed and require further enumeration and access-control testing. Credit Bureau API testing is pending in this iteration.

```
SupportsMultipleResults
  Status: Autocommit
  Salt: \x17\x1BF;rp=U\x1E\xeX(\x12\x07\x0B@M_h
  Auth Plugin Name: caching_sha2_password
  ssl-cert: Subject: commonName=MySQL_Server_8.0.46_Auto_Generated_Server_Certificate
  Not valid before: 2026-09-10T08:49:22
  Not valid after: 2036-09-07T08:49:22
  ssl-date: TLS randomness does not represent time
5001/tcp open  complex-link?
  fingerprint-strings:
    GetRequest, HTTPOptions:
      HTTP/1.1 404 NOT FOUND
      Server: Werkzeug/3.1.8 Python/3.11.16
      Date: Fri, 18 Sep 2026 18:41:57 GMT
      Content-Type: text/html; charset=utf-8
      Content-Length: 207
      Connection: close
      <!doctype html>
      <html lang=en>
      <title>404 Not Found</title>
      <h1>Not Found</h1>
      <p>The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.</p>
/p>
  Help:
    <!DOCTYPE HTML>
    <html lang="en">
    <head>
    <meta charset="utf-8">
    <title>Error response</title>
    </head>
    <body>
    <h1>Error response</h1>
    <p>Error code: 400</p>
```

Figure 7. Nmap NSE output for *paynova-creditbureau-api* – same Werkzeug 3.1.8 / Python 3.11.16 stack as the Card Scheme API.

3.2.4 172.21.0.99 — Analyst Toolbox (Payment NIC)

Host detected. No open TCP ports identified. Consistent with an assessment workstation.

3.3 Corporate Network — 172.22.0.0/24

3.3.1 172.22.0.10 — PAYNOVA-DC

This is the most significant host identified during initial enumeration. Discovered TCP services are listed below.

Port	Service	Observation
53/tcp	DNS	DNS service detected
88/tcp	Kerberos	Kerberos service detected
135/tcp	MSRPC	Microsoft Windows RPC
139/tcp	NetBIOS-SSN	Samba SMB service
389/tcp	LDAP	Anonymous Bind OK
445/tcp	SMB	Samba SMB 4.6.2
464/tcp	kpasswd5	Kerberos password change service
636/tcp	LDAPS	Anonymous Bind OK
3268/tcp	LDAP Global Catalog	Anonymous Bind OK
3269/tcp	LDAPS Global Catalog	Anonymous Bind OK
49152/tcp	MSRPC	Microsoft Windows RPC
49153/tcp	MSRPC	Microsoft Windows RPC
49154/tcp	MSRPC	Microsoft Windows RPC

Host identified as Windows via SMB fingerprint; NetBIOS name PAYNOVA-DC; Samba version 4.6.2. SMB2 message signing enabled and required.

Key security observations

1. LDAP anonymous bind

Nmap reported 'Anonymous Bind OK' on LDAP/LDAPS services. Validated in Section 4 (AD Reconnaissance) and carried forward as F-NET-001 in the consolidated findings register.

2. Extensive domain-controller exposure

DNS, Kerberos, LDAP, SMB, RPC, and Global Catalog services are all exposed. These services are expected on a domain controller, but their accessibility and configuration should be assessed against the intended network segmentation (see Section 5).

3. SMB signing

SMB2 message signing enabled and required. This is a positive security control (P-NET-001) and is documented for completeness.

```
root@c1lace6ea6da:~# nmap -Pn -p 53,88,135,139,389,445,464,636,3268,3269 172.22.0.10
Starting Nmap 7.93 ( https://nmap.org ) at 2026-09-18 14:32 UTC
Nmap scan report for paynova-ad.paynova-lab-pack_corpnet (172.22.0.10)
Host is up (0.00019s latency).

PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
389/tcp    open  ldap
445/tcp    open  microsoft-ds
464/tcp    open  kpasswd5
636/tcp    open  ldaps
3268/tcp   open  globalcatLDAP
3269/tcp   open  globalcatLDAPssl
MAC Address: CE:98:B5:C0:49:23 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds
root@c1lace6ea6da:~#
```

Figure 8. Nmap port validation of PAYNOVA-DC – all ten AD-related TCP ports observed open, including LDAP (389), LDAPS (636), and Global Catalog LDAP/LDAPS (3268/3269).

```
Windows PowerShell
supportedControl: 1.2.840.113556.1.4.2064
supportedControl: 1.2.840.113556.1.4.1339
supportedControl: 1.2.840.113556.1.4.1340
supportedControl: 1.2.840.113556.1.4.1413
supportedControl: 1.2.840.113556.1.4.1341
namingContexts: DC=paynova,DC=local
namingContexts: CN=Configuration,DC=paynova,DC=local
namingContexts: CN=Schema,CN=Configuration,DC=paynova,DC=local
namingContexts: DC=DomainDnsZones,DC=paynova,DC=local
namingContexts: DC=ForestDnsZones,DC=paynova,DC=local
supportedSASLMechanisms: GSS-SPNEGO
supportedSASLMechanisms: GSSAPI
supportedSASLMechanisms: NTLM
highestCommittedUSN: 4073
domainFunctionality: 4
forestFunctionality: 4
domainControllerFunctionality: 4
isGlobalCatalogReady: TRUE
MAC Address: CE:98:B5:C0:49:23 (Unknown)
Service Info: Host: PAYNOVA-DC; OS: Windows 2008 R2

Nmap done: 1 IP address (1 host up) scanned in 0.72 seconds
root@c1lace6ea6da:~# nmap -Pn -p 445 --script smb-os-discovery 172.22.0.10
Starting Nmap 7.93 ( https://nmap.org ) at 2026-09-18 15:03 UTC
Nmap scan report for paynova-ad.paynova-lab-pack_corpnet (172.22.0.10)
Host is up (0.000098s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
MAC Address: CE:98:B5:C0:49:23 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.89 seconds
root@c1lace6ea6da:~#
```

Figure 9. Nmap smb-os-discovery output – SMB service reports as 'Host: PAYNOVA-DC; OS: Windows 2008 R2' (Samba's default emulated-OS string; actual stack is Samba 4.6.2 per RootDSE vendorName).

3.3.2 172.22.0.99 – Analyst Toolbox (Corporate NIC)

Host detected. No open TCP ports identified.

3.4 Initial Attack-Surface Summary

The scan identified the following attack surfaces to be carried forward:

DMZ

- Nginx web portal (172.20.0.10)
- Web application on TCP/3000 (172.20.0.20)
- Potentially sensitive paths /backups/ and /app/administration (validated in Section 6)

Payment Network

- MySQL database (172.21.0.10)
- Card Scheme API (172.21.0.11)
- Credit Bureau API (172.21.0.12)

Corporate Network

- Domain controller with DNS, Kerberos, LDAP/LDAPS, SMB, RPC, Global Catalog exposure
- Anonymous LDAP/LDAPS binding on PAYNOVA-DC

Technology and version disclosures

- Nginx 1.27.5, MySQL 8.0.46, Werkzeug 3.1.8 / Python 3.11.16, Samba 4.6.2

4. Active Directory & Identity Security

Target: 172.22.0.10

Hostname: PAYNOVA-DC

Domain: PAYNOVA.LOCAL

4.1 Service Enumeration

LDAP RootDSE enumeration confirmed that 172.22.0.10 is an Active Directory Domain Controller for the PAYNOVA.LOCAL domain. The LDAP service exposes the domain naming context DC=paynova,DC=local. The server further exposes the following AD-related services:

- 53/tcp – DNS
- 88/tcp – Kerberos
- 135/tcp – MSRPC
- 389/tcp – LDAP
- 445/tcp – SMB
- 464/tcp – Kerberos password services
- 636/tcp – LDAPS
- 3268/tcp – Global Catalog LDAP
- 3269/tcp – Global Catalog LDAPS
- 49152–49154/tcp – MSRPC (dynamic)

The enumeration also identified the hostname PAYNOVA-DC and confirmed the system as an Active Directory domain controller. The RootDSE further disclosed vendorName 'Samba Team', dnsHostName paynova-dc.paynova.local, ldapServiceName paynova.local:paynova-dc\$@PAYNOVA.LOCAL, supportedSASLMechanisms (GSS-SPNEGO, GSSAPI, NTLM), highestCommittedUSN 4073, and domainFunctionality level 4. SMB2 message signing was observed to be enabled and required (positive control P-NET-001).

```

root@cllace6ea6da:~# nmap -Pn -p 389 --script ldap-rootdse 172.22.0.10
Starting Nmap 7.93 ( https://nmap.org ) at 2026-09-18 15:02 UTC
Nmap scan report for paynova-ad.paynova-lab-pack_corpnet (172.22.0.10)
Host is up (0.00023s latency).

PORT      STATE SERVICE
389/tcp   open  ldap
| ldap-rootdse:
| LDAP Results
| <ROOT>
| configurationNamingContext: CN=Configuration,DC=paynova,DC=local
| defaultNamingContext: DC=paynova,DC=local
| rootDomainNamingContext: DC=paynova,DC=local
| schemaNamingContext: CN=Schema,CN=Configuration,DC=paynova,DC=local
| subschemaSubentry: CN=Aggregate,CN=Schema,CN=Configuration,DC=paynova,DC=local
| supportedCapabilities: 1.2.840.113556.1.4.800
| supportedCapabilities: 1.2.840.113556.1.4.1670
| supportedCapabilities: 1.2.840.113556.1.4.1791
| supportedCapabilities: 1.2.840.113556.1.4.1935
| supportedCapabilities: 1.2.840.113556.1.4.2080
| supportedLDAPVersion: 2
| supportedLDAPVersion: 3
| vendorName: Samba Team (https://www.samba.org)
| isSynchronized: TRUE
| dsServiceName: CN=NTDS Settings,CN=PAYNOVA-DC,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=paynova,DC=local
| serverName: CN=PAYNOVA-DC,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=paynova,DC=local
| dnsHostName: paynova-dc.paynova.local
| ldapServiceName: paynova.local:paynova-dc$@PAYNOVA.LOCAL
| currentTime: 20260918150253.0Z
| supportedControl: 1.2.840.113556.1.4.1413
| supportedControl: 1.2.840.113556.1.4.1413
| supportedControl: 1.2.840.113556.1.4.1413

```

Figure 10. Nmap ldap-rootdse NSE output against 172.22.0.10:389 — unauthenticated query returned domain naming context, dsServiceName, serverName, dnsHostName paynova-dc.paynova.local, and vendorName ‘Samba Team’.

```

supportedControl: 1.2.840.113556.1.4.1413
supportedControl: 1.2.840.113556.1.4.1413
supportedControl: 1.2.840.113556.1.4.1413
supportedControl: 1.2.840.113556.1.4.1413
supportedControl: 1.2.840.113556.1.4.1413
supportedControl: 1.2.840.113556.1.4.528
supportedControl: 1.2.840.113556.1.4.841
supportedControl: 1.2.840.113556.1.4.319
supportedControl: 2.16.840.1.113730.3.4.9
supportedControl: 1.2.840.113556.1.4.473
supportedControl: 1.2.840.113556.1.4.1504
supportedControl: 1.2.840.113556.1.4.801
supportedControl: 1.2.840.113556.1.4.801
supportedControl: 1.2.840.113556.1.4.801
supportedControl: 1.2.840.113556.1.4.805
supportedControl: 1.2.840.113556.1.4.1338
supportedControl: 1.2.840.113556.1.4.529
supportedControl: 1.2.840.113556.1.4.417
supportedControl: 1.2.840.113556.1.4.2064
supportedControl: 1.2.840.113556.1.4.1339
supportedControl: 1.2.840.113556.1.4.1340
supportedControl: 1.2.840.113556.1.4.1413
supportedControl: 1.2.840.113556.1.4.1341
namingContexts: DC=paynova,DC=local
namingContexts: CN=Configuration,DC=paynova,DC=local
namingContexts: CN=Schema,CN=Configuration,DC=paynova,DC=local
namingContexts: DC=DomainDnsZones,DC=paynova,DC=local
namingContexts: DC=ForestDnsZones,DC=paynova,DC=local
supportedSASLMechanisms: GSS-SPNEGO
supportedSASLMechanisms: GSSAPI
supportedSASLMechanisms: NTLM
highestCommittedUSN: 4073
domainFunctionality: 4

```

Figure 11. LDAP RootDSE continuation — namingContexts, supportedSASLMechanisms, highestCommittedUSN 4073, domainFunctionality level 4.

4.2 Detailed Findings

4.2.1 Finding — LDAP RootDSE Information Disclosure

Finding ID	F-NET-001 (revised)
------------	---------------------

Category	Information Disclosure / Directory Services
Affected component	PAYNOVA-DC LDAP/LDAPS service
Severity	Low
Status	Confirmed (information disclosure only)

Description

The Nmap scan against PAYNOVA-DC reported 'Anonymous Bind OK' on LDAP and LDAPS ports (389, 636, 3268, 3269) and returned RootDSE metadata without authentication — including the domain naming context (DC=paynova,DC=local), configuration and schema naming contexts, DNS zones, vendorName ('Samba Team'), dnsHostName, and supportedSASL mechanisms. This is unauthenticated information disclosure at the directory-metadata layer.

Important validation

Follow-up testing with ldapsearch confirmed that anonymous bind does NOT permit unauthorised directory-object queries. The command 'ldapsearch -x -H ldap://172.22.0.10 -b "DC=paynova,DC=local" -s base "(objectClass=*)" dn' returned: 'result: 1 Operations error; text: 00002020: Operation unavailable without authentication'. The Nmap 'Anonymous Bind OK' result is a well-known false-positive-looking message: the LDAP service accepts an anonymous bind (technically true) but rejects directory-object operations that follow. This validation step is important — without it, the Nmap output could have been reported as a confirmed anonymous LDAP enumeration vulnerability.

```
root@3857d9782f70:~# mysql -h 172.21.0.10 -u root
ERROR 1045 (28000): Access denied for user 'root'@'172.21.0.99' (using password: NO)
root@3857d9782f70:~# docker compose exec -T paynova-webapp env | grep -Ei 'MYSQL|DATABASE|DB_'
bash: docker: command not found
root@3857d9782f70:~# docker compose exec -T paynova-webapp env
bash: docker: command not found
root@3857d9782f70:~# exit
exit
```

Figure 12. Terminal screenshot showing the ldapsearch command against DC=paynova,DC=local and the 'Operation unavailable without authentication' respons.

Impact

RootDSE metadata assists reconnaissance (an attacker can confirm the target is an Active Directory domain controller, identify the domain name, and learn the LDAP/SASL capability set). It does not by itself enable directory-object enumeration or authentication bypass. Severity is Low.

Recommended remediation

- For Samba: set 'ldap server require strong auth = yes' in smb.conf to restrict RootDSE responses to authenticated callers where the deployment permits.
- Enforce LDAP signing and channel binding (already configured — retain).
- Restrict LDAP/LDAPS at the network layer to authorised subnets and service accounts (aligns with the segmentation controls in §5).
- Upgrade Samba from 4.6.2 (out-of-support) to a currently-supported release.

4.2.2 Finding — Anonymous SMB Share Enumeration

Finding ID	F-AD-001
Category	Information Disclosure / SMB
Affected component	PAYNOVA-DC SMB service (Samba 4.17.12-Debian)
Severity	Medium
Status	Confirmed

Description

The PAYNOVA-DC SMB service permits anonymous share enumeration via smbclient with null authentication. The command 'smbclient -L //172.22.0.10 -N' succeeded and returned the list of SMB shares: print\$ (Printer Drivers) and IPC\$ (IPC Service). The response also disclosed the SMB service version (Samba 4.17.12-Debian).

Evidence sighted

- Command: smbclient -L //172.22.0.10 -N
- Response: 'Anonymous login successful'
- Shares disclosed: print\$ (Disk, 'Printer Drivers'), IPC\$ (IPC, 'IPC Service (Samba 4.17.12-Debian)')
- Positive follow-up: attempts to access print\$ content (smbclient //172.22.0.10/print\$ -N) returned 'NT_STATUS_ACCESS_DENIED' — see positive control P-AD-002.

```

root@3857d9782f70:~# smbclient -L //172.22.0.10 -N
Anonymous login successful

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      IPC$           IPC       IPC Service (Samba 4.17.12-Debian)
SMB1 disabled -- no workgroup available
root@3857d9782f70:~# smbclient //172.22.0.10/print$ -N
Anonymous login successful
tree connect failed: NT_STATUS_ACCESS_DENIED
root@3857d9782f70:~# smbclient //172.22.0.10/IPC$ -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
NT_STATUS_CONNECTION_REFUSED listing \*
smb: \>

```

Figure 13. Terminal screenshot showing smbclient -L //172.22.0.10 -N successfully listing print\$ and IPC\$ shares — screenshot to be attached in a subsequent iteration.

Impact

Unauthenticated attackers with network reach to PAYNOVA-DC can enumerate SMB share names and identify the Samba version. This provides reconnaissance value (confirms SMB service and version-specific vulnerabilities to research) and is a violation of the principle of minimum information disclosure. In isolation Medium; in aggregate with the version-disclosure findings elsewhere (§3.4) it lowers the cost of targeted attack.

Recommended remediation

- Disable anonymous / null SMB authentication where not required: on Samba, set 'restrict anonymous = 2' or 'server min protocol = SMB2' with appropriate 'map to guest = never' / 'guest ok = no' on all shares.
- Require authenticated sessions before disclosing share information.
- Restrict SMB exposure at the network layer to authorised administrative subnets only.
- Suppress or normalise the Samba version banner where the deployment allows.
- Upgrade to a currently-supported Samba release (aligns with R-022).

4.2.3 Finding — Weak Active Directory Password and Account Lockout Policy

Finding ID	F-AD-002
Category	Authentication / Identity
Affected component	PAYNOVA.LOCAL domain policy
Severity	Medium
Status	Confirmed

Description

Authenticated LDAP enumeration of the domain password policy identified two significant weaknesses. First, lockoutThreshold is set to 0 — failed authentication attempts do not result in account lockout, enabling unrestricted online password-guessing. Second, minPwdLength is set to 7 — passwords can be as short as seven characters, materially reducing resistance to guessing attacks especially where users select weak or predictable passwords.

Domain policy values observed

lockoutThreshold: 0 (no lockout); minPwdLength: 7 (very short); pwdHistoryLength: 24 (positive); pwdProperties: 1 (complexity enforced — positive baseline); maxPwdAge and minPwdAge configured (values in Windows-format 100-nanosecond intervals).

```
root@3857d9782f70:~# ldapsearch -N -Y GSSAPI -H ldap://paynova-dc.paynova.local \
-b 'DC=paynova,DC=local' \
-s base \
'(objectClass=domain)' \
minPwdLength pwdHistoryLength maxPwdAge minPwdAge pwdProperties lockoutThreshold lockoutDuration lockOutObservationWindow
SASL/GSSAPI authentication started
SASL username: Administrator@PAYNOVA.LOCAL
SASL SSF: 256
SASL data security layer installed.
# extended LDIF
#
# LDAPv3
# base <DC=paynova,DC=local> with scope baseObject
# filter: (objectClass=domain)
# requesting: minPwdLength pwdHistoryLength maxPwdAge minPwdAge pwdProperties lockoutThreshold lockoutDuration lockOutObservationW
indow
#
# paynova.local
dn: DC=paynova,DC=local
lockoutDuration: -18000000000
lockOutObservationWindow: -18000000000
lockoutThreshold: 0
maxPwdAge: -36288000000000
minPwdAge: -8640000000000
minPwdLength: 7
pwdProperties: 1
pwdHistoryLength: 24
# search result
search: 4
result: 0 Success
```

Figure 14. Screenshot of LDAP password-policy enumeration showing the six policy attributes (lockoutThreshold, minPwdLength, pwdHistoryLength, maxPwdAge, minPwdAge, pwdProperties).

Impact

The combination of no account lockout and a 7-character minimum length makes the domain highly susceptible to online password-guessing (from internal attackers) and to offline cracking if any password hash is exfiltrated (via R-045). For a financial-services environment this is materially below the expectations of the CBN Risk-Based Cybersecurity Framework and ISO 27001:2022 A.8.5 baseline.

Recommended remediation

- Configure a low `lockoutThreshold` (typically 3–10 failed attempts) with an appropriate `lockoutDuration` and `observationWindow` (15–30 minutes).
 - Increase `minPwdLength` to 12+ characters; encourage passphrases; retain existing complexity and history requirements.
 - Deploy MFA for privileged and other sensitive accounts (aligns with R-024).
 - Enable monitoring and alerting for repeated authentication failures.
 - Consider risk-based conditional-access policies for administrative logons.
-

4.2.4 Observation — Administrator Group Memberships

Authenticated LDAP enumeration confirmed the built-in Administrator account is a member of Domain Admins, Enterprise Admins, Schema Admins, Group Policy Creator Owners, and the Administrators group. Membership of the built-in Administrator in these groups is expected in a conventional Active Directory deployment and is not, by itself, evidence of an excessive-privilege vulnerability. The assessment did not establish a separate ordinary-user-to-Domain-Admins relationship from the evidence collected. This observation is documented for completeness; the operational recommendation to move to dedicated administrative accounts, JIT elevation, and privileged-access management is captured under R-031 in the risk register.

4.3 Positive Controls Observed

P-AD-001 — LDAP requires authentication for directory operations

Follow-up `ldapsearch` against the domain naming context (`DC=paynova,DC=local`) returned 'Operation unavailable without authentication'. The LDAP service correctly requires authentication for directory-object operations despite accepting anonymous bind at the transport layer.

P-AD-002 — SMB share content access denied for anonymous users

Attempts to access the `print$` share content anonymously (`smbclient //172.22.0.10/print$ -N`) returned 'NT_STATUS_ACCESS_DENIED'. Anonymous share enumeration succeeded (F-AD-001) but share content access is correctly restricted.

5. Network Segmentation Findings

Segmentation testing was performed by pinning netcat to specific container network namespaces via 'docker run --rm --network container:<target-container> busybox nc -zvw 3 <destination> <port>'. This technique allows the assessment to prove – rather than assume – whether ordinary DMZ or Payment application infrastructure can reach a given destination.

5.1 Finding – Excessive DMZ-to-Payment Network Access

Finding ID	F-NET-002
Category	Network Segmentation
Severity	High
Status	Confirmed

Description

Connectivity testing from the paynova-webapp DMZ network namespace confirmed that the DMZ can directly reach all identified Payment-network services: MySQL (172.21.0.10:3306), Card Scheme API (172.21.0.11:5001), and Credit Bureau API (172.21.0.12:5002). This demonstrates that ordinary application infrastructure in the DMZ has network-level access to the Payment network. Compromise of the public-facing web application therefore provides a direct network path to the payment database and both payment APIs.

Test evidence table

Source →Destination →Result

Source	Destination	Result
paynova-webapp (DMZ)	172.21.0.10:3306 – MySQL	OPEN
paynova-webapp (DMZ)	172.21.0.11:5001 – Card Scheme API	OPEN
paynova-webapp (DMZ)	172.21.0.12:5002 – Credit Bureau API	OPEN

```

PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-webapp busybox nc -zvw 3
172.21.0.10 3306
Unable to find image 'busybox:latest' locally
latest: Pulling from library/busybox
b05093807bb0: Pull complete
7270b3e1860c: Download complete
Digest: sha256:dc2d74b28e4cf8984fa52af1f39bc7c3d9c73760b41a74d629f5d11b1ab28616
Status: Downloaded newer image for busybox:latest
172.21.0.10 (172.21.0.10:3306) open
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-webapp busybox nc -zvw 3
172.21.0.11 5001
172.21.0.11 (172.21.0.11:5001) open
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-webapp busybox nc -zvw 3
172.21.0.12 5002
172.21.0.12 (172.21.0.12:5002) open
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> |

```

Figure 15. Direct proof of DMZ–Payment reachability: nc executed inside the paynova-webapp network namespace against each Payment–network service; all three targets returned ‘open’.

Important distinction

This proves network reachability. It does not by itself prove that the applications are vulnerable or that authentication can be bypassed. Application-layer weaknesses on the reachable payment services are reported separately in Section 7.

Recommended remediation

- Introduce an internal firewall or Docker network policy between the DMZ and Payment segments; deny all traffic by default and allow only specific application flows.
- For paynova-webapp →paynova-db, allow only TCP/3306 sourced from the application service account, with mutual TLS and least-privilege database credentials.
- For paynova-webapp →payment APIs, terminate calls through an internal API gateway that enforces authentication, request signing, and rate limiting rather than allowing direct TCP reachability.
- Add continuous segmentation-validation checks so that drift is detected between formal assessments (PCI DSS 11.4.5).

5.2 Finding — DMZ-to-Corporate Network Segmentation

Finding ID	P-NET-002
Category	Network Segmentation
Severity	Positive
Status	Control observed as effective

Description

Connectivity testing from the paynova-webapp DMZ network namespace to PAYNOVA-DC (172.22.0.10) resulted in connection timeouts across DNS (53), Kerberos (88), LDAP (389), SMB

(445), and LDAPS (636). This indicates that the ordinary DMZ web application does not have network-level access to the corporate/AD network through the tested services.

```
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-webapp busybox nc -zvw 3 172.22.0.10 53
nc: 172.22.0.10 (172.22.0.10:53): Connection timed out

What's next:
  Debug this container error with Gordon → docker ai "help me fix this container error"
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-webapp busybox nc -zvw 3 172.22.0.10 88
nc: 172.22.0.10 (172.22.0.10:88): Connection timed out

What's next:
  Debug this container error with Gordon → docker ai "help me fix this container error"
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-webapp busybox nc -zvw 3 172.22.0.10 389
nc: 172.22.0.10 (172.22.0.10:389): Connection timed out

What's next:
  Debug this container error with Gordon → docker ai "help me fix this container error"
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-webapp busybox nc -zvw 3 172.22.0.10 445
nc: 172.22.0.10 (172.22.0.10:445): Connection timed out

What's next:
  Debug this container error with Gordon → docker ai "help me fix this container error"
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-webapp busybox nc -zvw 3 172.22.0.10 636
nc: 172.22.0.10 (172.22.0.10:636): Connection timed out

What's next:
  Debug this container error with Gordon → docker ai "help me fix this container error"
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> |
```

Figure 16. Direct segmentation proof – nc from paynova-webapp (DMZ) to PAYNOVA-DC on TCP 53, 88, 389, 445, and 636: every port returned ‘Connection timed out’.

5.3 Finding — Payment-to-AD Segmentation

Finding ID	P-NET-003
Category	Network Segmentation
Severity	Positive
Status	Control observed as effective

Description

Connectivity testing from the PayNova Card Scheme API (Payment network) to PAYNOVA-DC (172.22.0.10) resulted in timeouts on DNS (53), Kerberos (88), LDAP (389), SMB (445), and LDAPS (636). Based on the tested services, the Payment network does not have direct network connectivity to the AD server.

```

PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-cardscheme-api busybox nc -zv 172.22.0.10 53
nc: 172.22.0.10 (172.22.0.10:53): Connection timed out

What's next:
Debug this container error with Gordon → docker ai "help me fix this container error"
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-cardscheme-api busybox nc -zv 172.22.0.10 88
nc: 172.22.0.10 (172.22.0.10:88): Connection timed out

What's next:
Debug this container error with Gordon → docker ai "help me fix this container error"
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-cardscheme-api busybox nc -zv 172.22.0.10 389
nc: 172.22.0.10 (172.22.0.10:389): Connection timed out

What's next:
Debug this container error with Gordon → docker ai "help me fix this container error"
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-cardscheme-api busybox nc -zv 172.22.0.10 445
nc: 172.22.0.10 (172.22.0.10:445): Connection timed out

What's next:
Debug this container error with Gordon → docker ai "help me fix this container error"
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-cardscheme-api busybox nc -zv 172.22.0.10 636
nc: 172.22.0.10 (172.22.0.10:636): Connection timed out

What's next:
Debug this container error with Gordon → docker ai "help me fix this container error"
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack>

```

Figure 17. Direct segmentation proof — nc from paynova-cardscheme-api (Payment) to PAYNOVA-DC on TCP 53, 88, 389, 445, and 636: every port returned 'Connection timed out'.

5.4 Note — Toolbox Network Reachability

The assessment toolbox is attached to all three PayNova network segments (DMZ, Payment, Corporate). Connectivity testing confirmed that the toolbox can reach the tested Payment services and Active Directory services, including DNS, Kerberos, LDAP, and SMB. This access is intentional for security-assessment purposes and should not be treated by itself as a segmentation vulnerability. It is documented so that the operational team can distinguish assessment-workstation traffic from unexpected cross-segment activity during log review.

```

PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-toolbox busybox nc -zv 172.22.0.10 53
172.22.0.10 (172.22.0.10:53) open
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-toolbox busybox nc -zv 172.22.0.10 88
172.22.0.10 (172.22.0.10:88) open
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-toolbox busybox nc -zv 172.22.0.10 389
172.22.0.10 (172.22.0.10:389) open
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker run --rm --network container:paynova-toolbox busybox nc -zv 172.22.0.10 445
172.22.0.10 (172.22.0.10:445) open
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack>

```

Figure 18. Toolbox reachability baseline — nc from paynova-toolbox to PAYNOVA-DC on TCP 53, 88, 389, and 445: all returned 'open'.

5.5 Questions Asked During Testing

Q1 — Can the DMZ reach the Payment network?

Yes.

Connectivity testing from the DMZ web application to Payment services confirmed access to: 172.21.0.10:3306 — OPEN; 172.21.0.11:5001 — OPEN; 172.21.0.12:5002 — OPEN. Observation: the DMZ web application has network-level connectivity to the Payment network.

Q2 — Can the DMZ reach the Corporate network?

No, based on the tested paths.

Connectivity testing from the DMZ web application to the AD server was unsuccessful. Observation: direct DMZ-to-Corporate connectivity to the tested AD services is restricted.

Q3 — Can Payment services reach AD?

No, based on the tested paths.

The Payment Card Scheme API was tested against 172.22.0.10 on TCP 53, 88, 389, 445, and 636 — all returned TIMEOUT. Observation: the tested Payment-to-AD paths are blocked.

Q4 — Can the toolbox reach everything?

The toolbox has broad cross-segment reachability.

Testing confirmed access from the toolbox to Payment (3306/5001/5002), Corporate/AD (53/88/389/445), and DMZ (80/443). Observation: consistent with the toolbox's intended role as the assessment workstation.

Section conclusion

The segmentation testing demonstrates that ordinary application traffic is more restricted than the assessment toolbox. The DMZ web application can reach tested Payment services but not the tested AD services, while the Payment Card Scheme API could not reach the tested AD services. The assessment toolbox, by design, has connectivity across DMZ, Payment, and Corporate networks.

6. Web Application Testing Findings

This section reports the findings raised during web application testing against the PayNova customer portal (Nginx web/edge tier, <http://localhost:8080/>) and the customer-facing OWASP Juice Shop instance (<http://localhost:8082/>). Testing followed OWASP WSTG-aligned methodology, with authenticated and unauthenticated requests issued via browser and Burp Suite Repeater.

6.1 Unauthenticated Exposure of Sensitive Customer Backup Data

Finding ID	PN-WEB-001
Category	Web Application / Security Misconfiguration / Sensitive Data Exposure
Affected component	PayNova Nginx web/edge tier
Affected URL	http://localhost:8080/backups/
Finding type	Confidentiality
Severity	High
Authentication required	No
User interaction required	No
Status	Confirmed & exploited

Description

The `/backups/` directory served by the PayNova Nginx web/edge tier is publicly accessible and permits directory listing. An unauthenticated HTTP GET to <http://localhost:8080/backups/> returns an HTML index page listing the file `paynova_customers_backup_2026-08-15.csv`, which can be downloaded directly via HTTP GET without any authentication challenge. The CSV contains 5 customer records with columns `customer_id`, `full_name`, `email`, `national_id`, `card_number`, `cvv`, and `wallet_pin`.

Primary weakness

Security misconfiguration combined with sensitive data exposure. Two independent PCI DSS failures are present in a single artefact: (1) the file is exposed without access control; and (2) the file itself contains Sensitive Authentication Data (CVV) and cardholder PINs, which under

PCI DSS v4.0.1 Requirement 3.3 must not be stored after authorisation under any circumstances, irrespective of the storage location or encryption state.

Evidence sighted

- Unauthenticated HTTP GET `http://localhost:8080/backups/` returns HTTP 200 with an Nginx-generated 'Index of `/backups/`' page (Figure below).
- Unauthenticated HTTP GET of the CSV file returns HTTP 200 with the full CSV body; no authentication or authorisation check is issued.
- CSV file (496 bytes) contains header row 'customer_id,full_name,email,national_id,card_number,cvv,wallet_pin' and 5 data rows covering Nigerian (NG-), UK (UK-), and German (DE-) customer records.
- Card numbers observed include Visa test range (4111 prefix) and Mastercard test range (55/50 prefix) – evidence that data is simulated lab data; the record shape is realistic.
- This is the validated exploitation of the `/backups/` path first disclosed via robots.txt during reconnaissance (see Section 3.1.1).

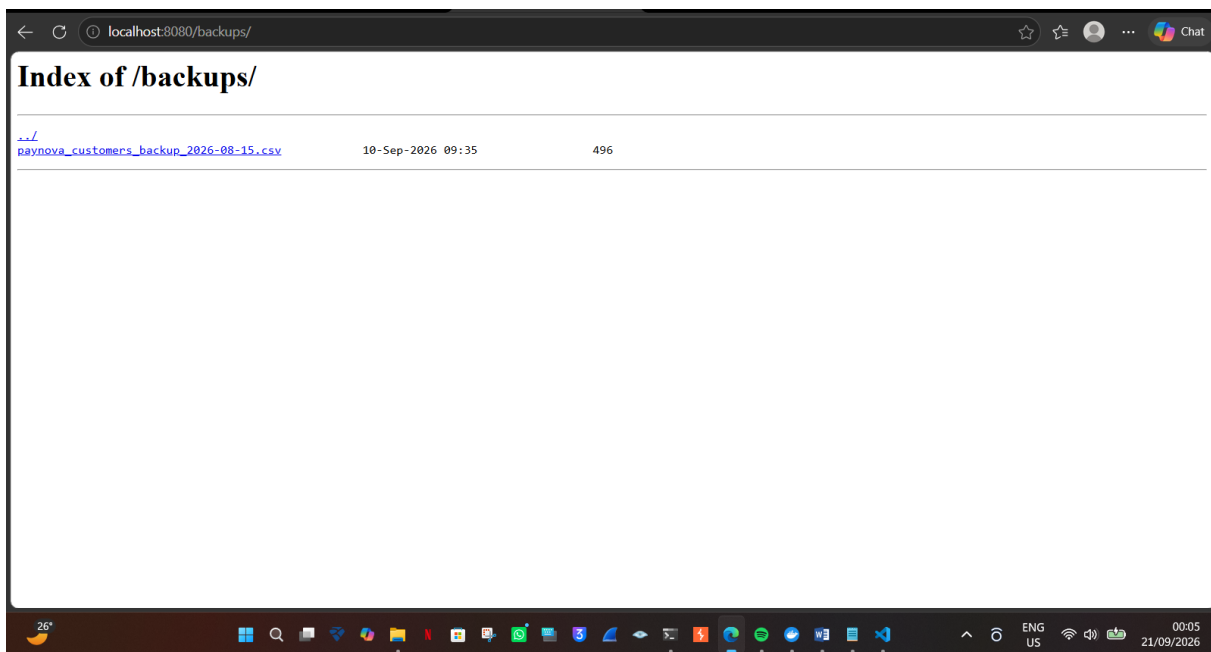


Figure 19. Unauthenticated request to `http://localhost:8080/backups/` from an ordinary browser returns an Nginx-generated 'Index of `/backups/`' page listing `paynova_customers_backup_2026-08-15.csv` (496 bytes).

	A	B	C	D	E	F	G	H	I	J
	customer_full_name	email	national_id	card_number	cvv	wallet_pin				
1	1 Adaeze Okonkwo	adaeze.okonkwo@example.com	NG-19850312-001	5.06146E+15	123	1234				
2	2 Tunde Balogun	tunde.balogun@example.com	NG-19900701-002	5.5E+15	456	4321				
3	3 Chiamaka Eze	chiamaka.eze@example.com	NG-19921115-003	4.11111E+15	789	0				
4	4 James Whitfield	james.whitfield@example.co.uk	UK-19881204-004	4.11111E+15	321	1111				
5	5 Sophie Bergmann	sophie.bergmann@example.de	DE-19950630-005	5.5E+15	654	2580				

Figure 20. Contents of the downloaded CSV — 5 customer records with full_name, email, national_id, card_number, cvv, and wallet_pin populated. In a live-production engagement the card_number, cvv, and wallet_pin columns would be redacted in the report body; the image is shown unredacted here because this is simulated lab data.

Impact

Loss of confidentiality is direct and requires no authentication. The exposed data (name, email, national ID, PAN, CVV, wallet PIN) is sufficient to enable card-not-present fraud, wallet takeover, and targeted phishing without any further compromise. In a real environment this would trigger data-breach notification obligations under NDPA 2023 for Nigerian data subjects and — given the UK and German records in the sample — potentially under UK/EU GDPR (Article 33, 72-hour notification window).

Recommended remediation

- Immediate: return HTTP 403 or 404 for all requests to /backups/* at the Nginx layer; delete the exposed CSV from every web-served path.
- Immediate: treat as a suspected data breach — trigger incident response per the PayNova Incident Response Plan v1.0 (PN-WEB-001 is the worked example throughout that document); preserve web-server access logs; force PAN reissuance and wallet PIN reset for the 5 affected records.
- Structural: eliminate CVV from all storage — CVV must never be persisted (PCI DSS 3.3). Review the backup-generation code and remove the cvv column at source.
- Structural: relocate customer backups to storage that is not under any Nginx server_root.

- Configuration: disable Nginx directory indexing globally ('autoindex off;') and deny common backup extensions (.csv, .sql, .bak, .zip, .tar, .gz, .dump) at the location block.
- Assurance: conduct content-discovery testing (Gobuster/FFUF) against the portal and every other public-facing service; add a CI/CD test that fails the build if a backup file is present under any web-served path.
- Privacy: notification obligations under NDPA s.40, GDPR Art. 33/34, and UK GDPR Art. 33/34 apply — see PIA v1.0 PR-03 and IRP v1.0 §7 for the specific 72-hour windows and notification recipients.

6.2 SQL Injection — Authentication Bypass to Administrator Account

Finding ID	WEB-SQLI-001
Category	Injection / Authentication Bypass / Privilege Escalation
OWASP	A03:2021 — Injection; CWE-89 (Improper Neutralization of Special Elements in SQL)
Affected endpoint	POST /app/rest/user/login (email parameter)
Affected component	OWASP Juice Shop (paynova-webapp)
Severity	Critical
Authentication required	No
Status	Confirmed

Description

The Juice Shop login functionality was tested for SQL injection by manipulating the email parameter of the authentication request. The application failed to prevent SQL syntax from affecting the backend authentication query, allowing the authentication logic to be manipulated so that authentication succeeded without supplying the legitimate administrator's password. The resulting session was confirmed as the administrator account.

Testing methodology

Assessment performed using Burp Suite Repeater against the locally hosted Juice Shop instance. Baseline invalid-credentials request was captured and modified to inject SQL

syntax into the email parameter of the JSON body posted to /app/rest/user/login. The classic bypass payload of the form ' OR 1=1-- was used (exact payload retained in analyst working notes; not reproduced here to avoid trivial replay).

Observed response

The application returned HTTP/1.1 200 OK with an authentication object and a JWT/session token. Following the successful authentication response, the browser session was observed to be authenticated as admin@juice-shop.op, and administrator-level functionality (administrative account options) was displayed in the UI. This confirms the issue was not merely a login-response manipulation — SQL injection resulted in an authenticated administrator session.

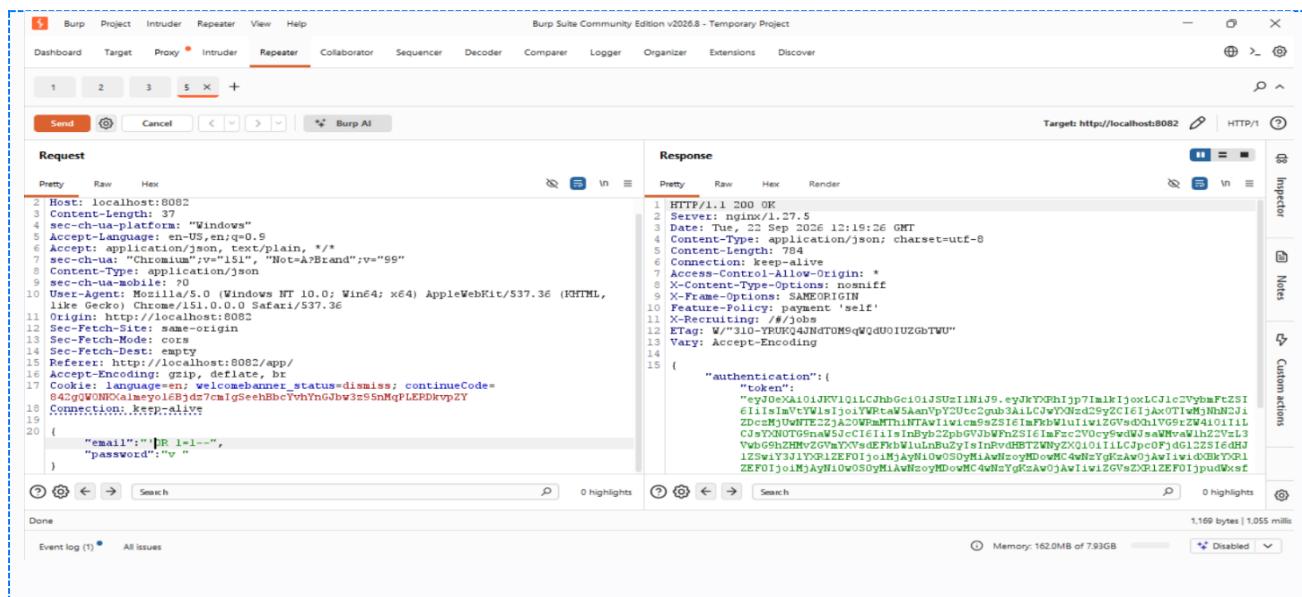


Figure 21. Burp Suite Repeater screenshot showing the modified POST /app/rest/user/login request with SQL injection payload in the email parameter, and the HTTP 200 OK response containing an authentication token.

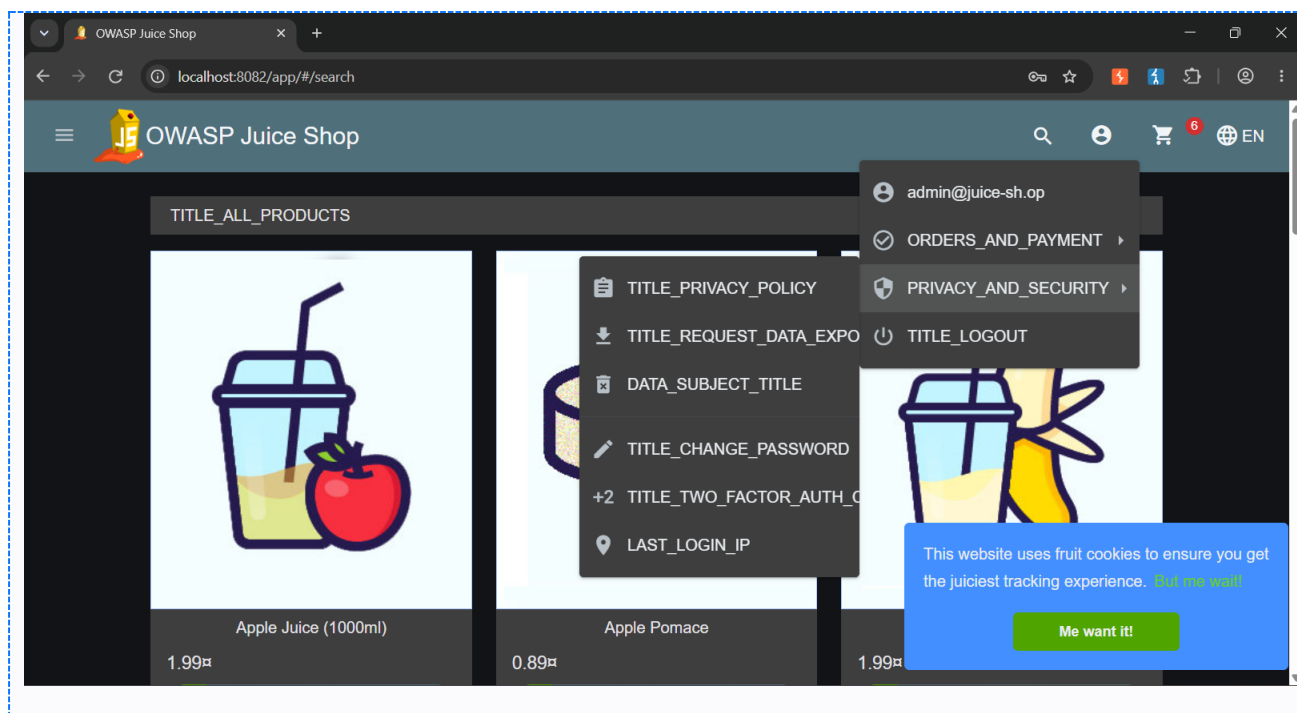


Figure 22. Juice Shop UI screenshot showing the authenticated session as `admin@juice-shop.op` with administrator-only functionality visible.

Impact

Successful exploitation allows an unauthenticated attacker to bypass the application's authentication mechanism. Because the compromised account carries administrator privileges, the impact extends to unauthorised access to administrator functionality, privileged application data, modification of administrative resources, and potential compromise of further application functionality. Loss of confidentiality, integrity, and potentially availability. The privilege-escalation aspect increases the impact substantially compared with a SQL injection limited to ordinary user access.

Recommended remediation

- Replace dynamically-constructed SQL with parameterised queries / prepared statements throughout the authentication path.
- Implement server-side input validation for the email parameter (RFC 5321/5322 shape).
- Never construct SQL through direct string concatenation of user-controlled input.
- Replace weak password hashing (MD5) with Argon2id, bcrypt, or scrypt.
- Apply least-privilege permissions to the application's database account.
- Add SQL injection tests to the application's security regression testing and CI/CD pipeline.

- Retest login after remediation using the same payload family; confirm the response is HTTP 401/403 with no authentication token issued.

6.3 Broken Object-Level Authorization — Unauthorised Basket Access

Finding ID	PH10-003
Category	Authorisation / Broken Object Level Authorization (BOLA)
OWASP	A01:2021 — Broken Access Control; API1:2023 — BOLA
Affected endpoint	GET /app/rest/basket/{id}
Affected component	OWASP Juice Shop (paynova-webapp)
Severity	Medium
Authentication required	Yes (any authenticated user)
Status	Confirmed

Test objective

Determine whether an authenticated user can access another user's basket by modifying the basket object identifier in the API request.

Methodology

An authenticated request to the basket API was first observed (GET /app/rest/basket/6 with Authorization: Bearer <token>). The request was sent through Burp Suite Repeater. The basket identifier was then modified to /app/rest/basket/1 while keeping the same authentication token. No other authorisation-related value was changed.

Result

The modified request returned HTTP/1.1 200 OK with basket information for user 1 (a different account than the authenticated session's owner). The response contained the basket object including id, userId, coupon, timestamps, and product list. The critical observation is that changing the object identifier resulted in successful retrieval of another user's basket while retaining the original authenticated session.

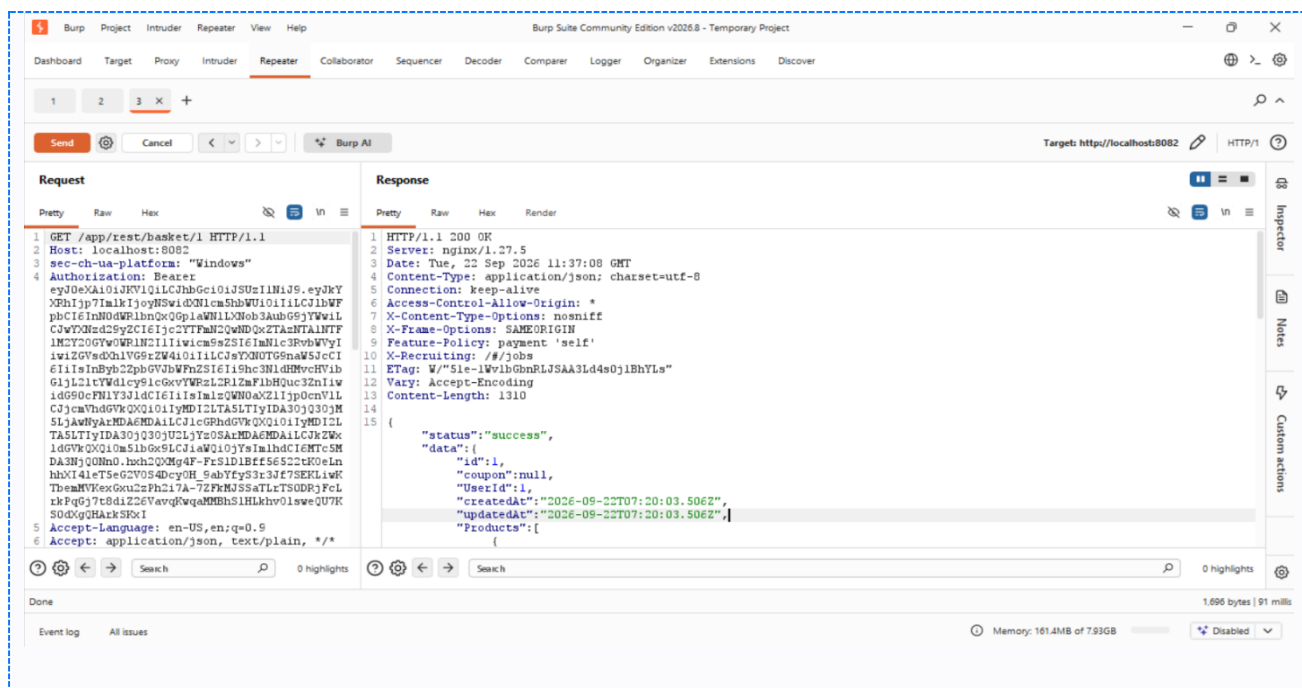


Figure 23. Burp Suite Repeater screenshot showing the authenticated GET `/app/rest/basket/1` request (with the requesting user's own bearer token) and the HTTP 200 OK response returning basket data belonging to `userId=1`.

Security impact

An attacker who is already authenticated can manipulate object identifiers to access resources belonging to other users. Depending on the affected endpoint this can expose personal information, order/basket information, or other user-specific data. The vulnerability is a textbook Broken Object Level Authorization pattern and typically extends across other object-identifier endpoints in the same application until an authorisation check is added at the server side.

Recommended remediation

- Perform server-side object-level authorisation on every basket request: check that `basket.userId == authenticated_user.id` before returning the object.
- Apply the same check pattern across every other endpoint that accepts a resource identifier in the URL or body.
- Do not rely on the client to provide a valid basket ID, or assume that knowledge of an identifier implies authorisation.
- Consider migrating to opaque, unguessable identifiers (UUIDs) as defence-in-depth – but the authorisation check is the primary control, not identifier obfuscation.

- Add automated authorisation-regression tests covering identifier-swap attacks for every user-owned resource.

6.4 Broken Access Control — Unauthorised Access to Administrative Application Configuration

Finding ID	WEB-BAC-001
Category	Authorisation / Missing Authorisation
OWASP	A01:2021 — Broken Access Control; CWE-862 (Missing Authorization)
Affected endpoint	GET /app/rest/admin/application-configuration
Affected component	OWASP Juice Shop (paynova-webapp)
Severity	Medium
Authentication required	Yes (any authenticated user, including non-admin)
Status	Confirmed

Description

The application exposes the administrative application-configuration endpoint without adequately enforcing authorisation. Testing was performed by authenticating as a non-administrative user (student1) and issuing a request to /app/rest/admin/application-configuration through Burp Suite Repeater while retaining the user's authentication token. The endpoint returned HTTP 200 OK with application configuration information intended for administrative users. Severity may be increased if the exposed administrative endpoint returns sensitive credentials, secrets, internal infrastructure information, or functionality that enables further compromise.

Testing methodology

(1) Authenticate to the application as a non-administrative account. (2) Capture the authenticated request in Burp Suite. (3) Modify the request to target GET /app/rest/admin/application-configuration. (4) Send the request via Burp Repeater while retaining the user's authentication token. (5) Observe the server response. (6) Verify whether the server returns administrative configuration to the low-privileged user.

- Audit every /admin/* route (and equivalent) and confirm each requires an appropriate role.
- Adopt a central authorisation-decision function (middleware or policy engine) rather than sprinkling checks across handlers.
- Add automated regression tests that authenticate as a non-admin and assert that admin endpoints return 401/403.

6.5 DOM-Based Cross-Site Scripting

Finding ID	PH10-004
Category	Injection / Cross-Site Scripting
OWASP	A03:2021 – Injection; CWE-79
Affected endpoint	GET /#/search (parameter: q)
Affected component	OWASP Juice Shop (paynova-webapp)
Severity	Medium
Authentication required	No
Status	Confirmed

Description

The application processes attacker-controlled input from the URL query parameter `q` through client-side JavaScript and inserts it into the DOM without adequate sanitisation or encoding. A crafted payload of the form `<iframe src="javascript:alert('XSS')">` supplied via the `q` parameter results in JavaScript execution in the application's origin, evidenced by a browser alert displaying XSS.

Proof of concept

URL: `http://localhost:8082/#/search?q=<iframe src="javascript:alert('XSS')">`. The browser rendered the injected iframe and executed the JavaScript URI, producing an alert dialog with the text 'XSS'. The URL bar retained the encoded payload, confirming that the input reached a JavaScript execution sink without adequate encoding.

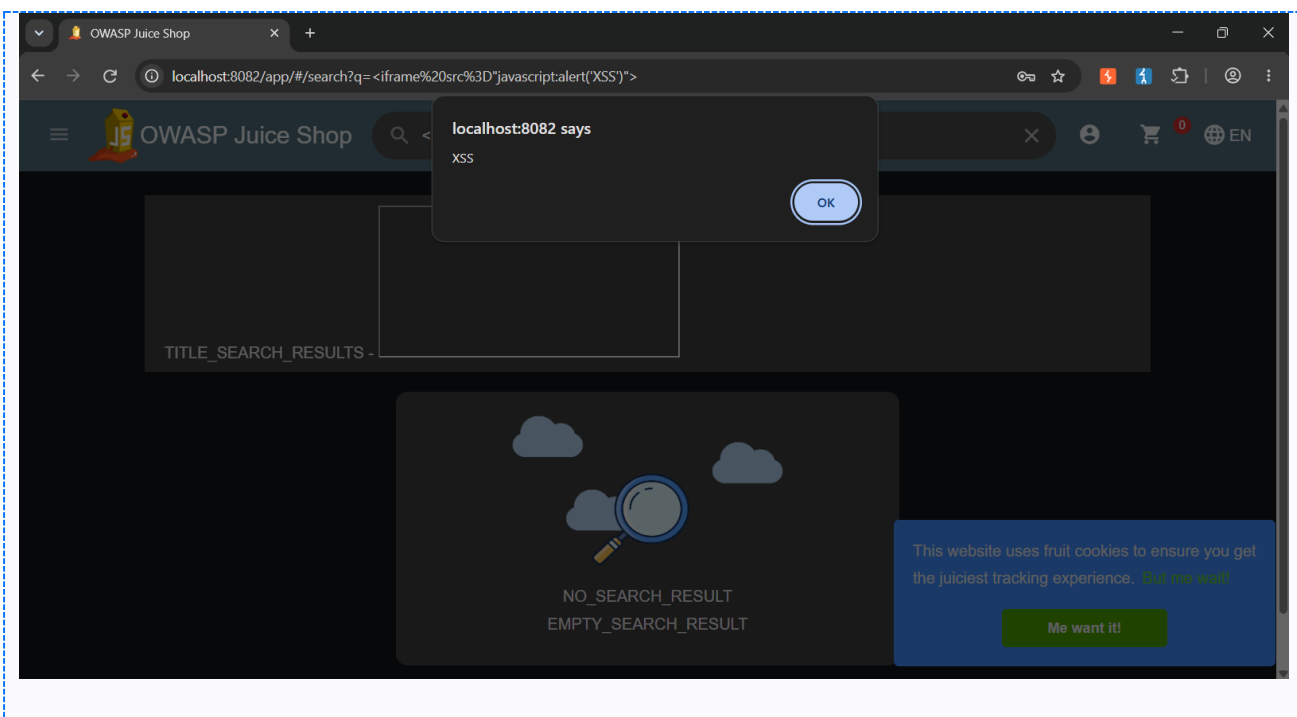


Figure 25. Browser screenshot showing the URL bar with the injected iframe payload in the *q* parameter and the resulting JavaScript alert dialog displaying 'XSS'.

Impact

DOM-based XSS allows an attacker to execute arbitrary JavaScript in another user's browser under the application's origin. Depending on the application's security controls this can lead to unauthorised actions in the victim's session, theft of accessible application data, manipulation of application content, phishing within the trusted application origin, and abuse of authenticated functionality.

Recommended remediation

- Do not insert untrusted URL parameters directly into HTML/DOM sinks.
- Prefer safe DOM APIs such as `textContent` where HTML is not required; avoid `innerHTML` where possible.
- If HTML must be accepted, apply a well-maintained allowlist-based HTML sanitiser.
- Validate and constrain the *q* parameter according to its intended format.
- Deploy an appropriate Content Security Policy (CSP) as defence in depth.
- Avoid dangerous JavaScript execution functions such as `eval()`.
- Add automated XSS regression tests for URL-controlled inputs.

6.6 Session Token Replay — Token Remains Valid After Logout

Finding ID	FIND-008
Category	Authentication / Session Management
OWASP	A07:2021 — Identification and Authentication Failures
Affected component	OWASP Juice Shop REST API (paynova-webapp)
Severity	Medium
Authentication required	Yes (initially)
Status	Confirmed

Description

A previously-issued authentication token remained valid after the associated user session was terminated through the application's logout functionality. The previously-captured token was replayed against an authenticated API request after logout, and the server returned HTTP/1.1 200 OK with application data. This indicates that logout does not immediately invalidate the previously-issued authentication token.

Methodology

(1) Authenticate to the application and capture the JWT/session token issued by the login endpoint. (2) Log out of the application through the standard UI logout flow. (3) Replay an authenticated API request using the captured token via Burp Suite Repeater. (4) Observe the server response.

Result

The replayed request returned HTTP 200 OK with the expected authenticated response body. The token continued to authorise API access despite the user having explicitly logged out.

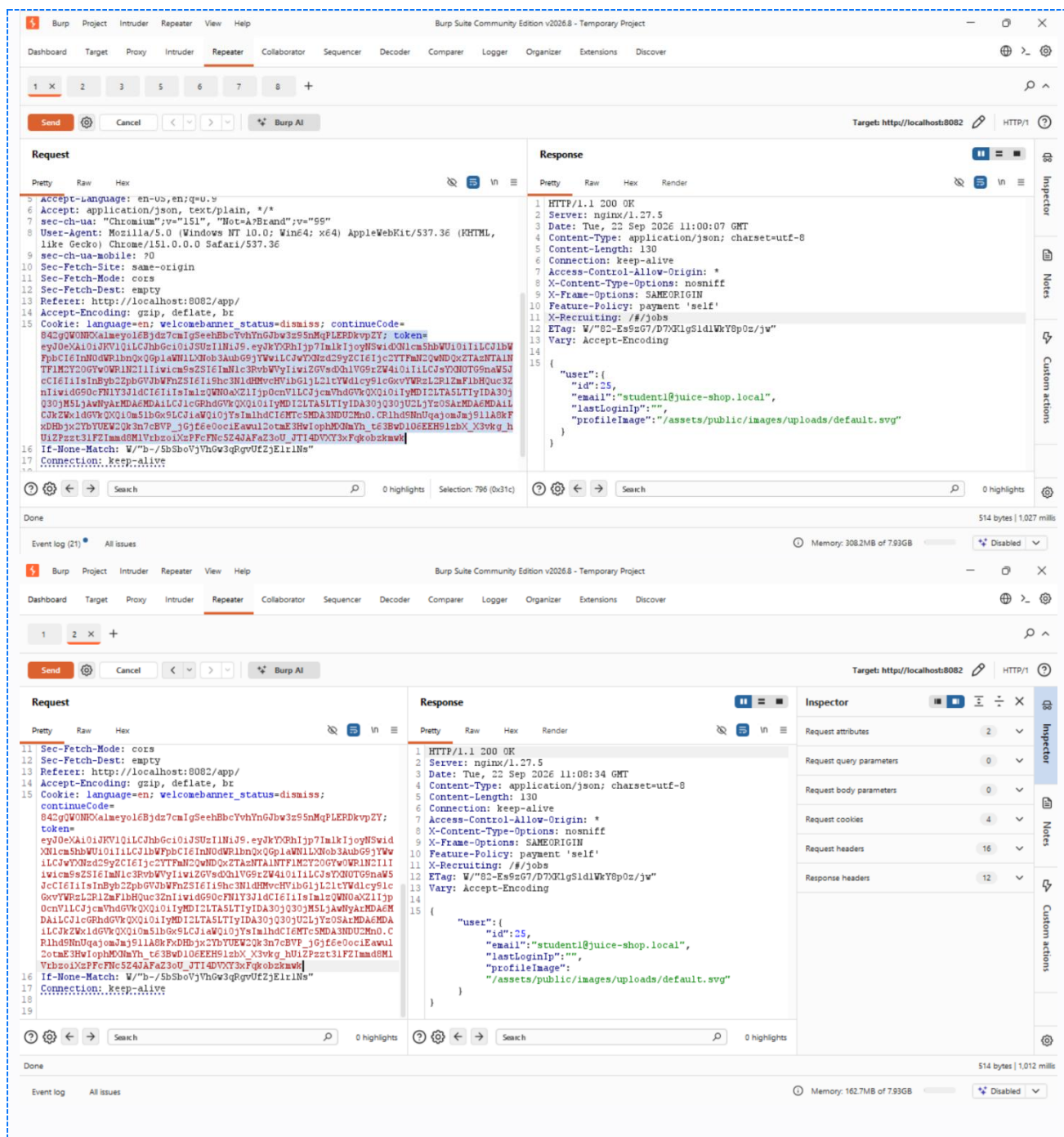


Figure 26. Burp Suite Repeater screenshot showing the replayed authenticated API request using a post-logout token, and the HTTP 200 OK response with authenticated content.

Impact

If an authentication token is obtained by an unauthorised party, logging out through the application does not prevent continued use of the token until it otherwise expires. This extends the useful lifetime of a compromised session credential and defeats users who log out believing their session has been terminated (for example on shared devices).

Recommended remediation

- Maintain a server-side token revocation list (deny-list) and reject revoked tokens on every authenticated request.
 - Or, use short-lived access tokens (5–15 minutes) with refresh tokens tied to a server-side session; revoke the refresh token on logout.
 - Ensure logout invalidates the session/token server-side, not just client-side.
 - Consider binding tokens to user-agent or client fingerprint characteristics as defence in depth.
 - Add automated regression tests that assert a post-logout token is rejected by the API.
-

6.7 Server Version Information Disclosure

Finding ID	WEB-INFO-001
Category	Information Disclosure
OWASP	OWASP ASVS V14.3 (HTTP response header security)
Affected component	PayNova Nginx web tier (paynova-portal)
Severity	Low
Authentication required	No
Status	Confirmed

Description

HTTP responses from the PayNova Nginx web tier include the header 'Server: nginx/1.27.5'. This discloses the specific web-server product and version and can assist an attacker in identifying version-specific vulnerabilities or configuration weaknesses. This finding overlaps with the network-layer version disclosure captured under Section 3.4 but is recorded separately as an application-tier observation from Burp Suite.

Evidence

Burp response headers observed against <http://localhost:8080/> include 'Server: nginx/1.27.5'.

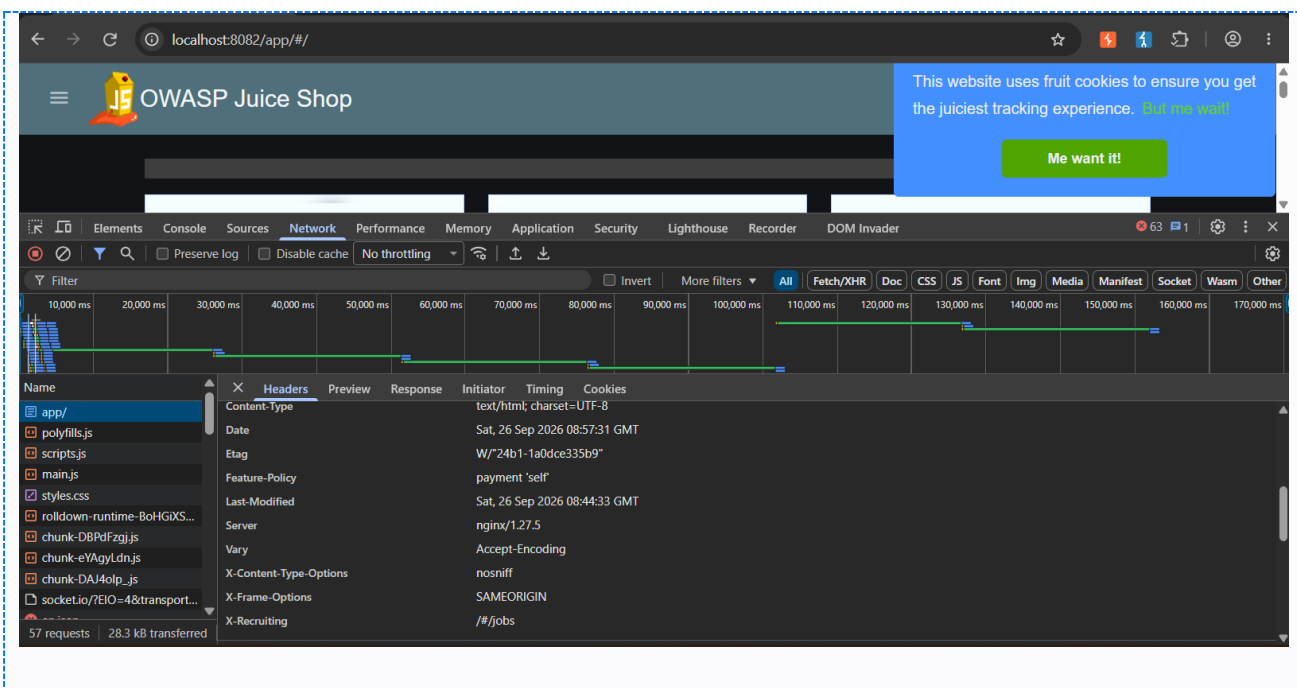


Figure 27. Burp Suite response headers screenshot showing 'Server: nginx/1.27.5' on a response from the PayNova portal.

Impact

An attacker can identify the web-server software and version and use that information to research version-specific vulnerabilities or configuration weaknesses. Severity is Low in isolation; it would rise if the disclosed version was later found to have unpatched CVEs.

Recommended remediation

- Suppress the Server header via 'server_tokens off;' in the Nginx configuration.
- Consider using an 'more_clear_headers Server;' directive (ngx_headers_more module) to remove the header entirely.
- Ensure timely patching for nginx and monitor CVEs against the running version.

7. API Testing Findings

This section reports findings against the PayNova Card Scheme API (paynova-cardscheme-api, 172.21.0.11:5001). Testing of the Credit Bureau API (172.21.0.12:5002) is pending. Given the identical stack (Werkzeug/Flask) and shared deployment pattern, the findings raised against the Card Scheme API should be treated as likely-applicable to the Credit Bureau API until verified.

7.1 Unauthenticated Card Data Enumeration and Excessive Sensitive Data Exposure

Finding ID	PAYNOVA-API-001
Category	Broken Authentication / Broken Function Level Authorization / Excessive Data Exposure
OWASP API Security	API5:2023 — Broken Function Level Authorization; API1:2023 — BOLA; API3:2023 — Broken Object Property Level Authorization
CWE	CWE-862 (Missing Authorization); CWE-200 (Exposure of Sensitive Information); CWE-359 (Exposure of Private Personal Information)
Affected component	PayNova Card Scheme API
Affected endpoint	GET /cards
Affected host	172.21.0.11:5001
Severity	Critical
Authentication required	No
Status	Confirmed

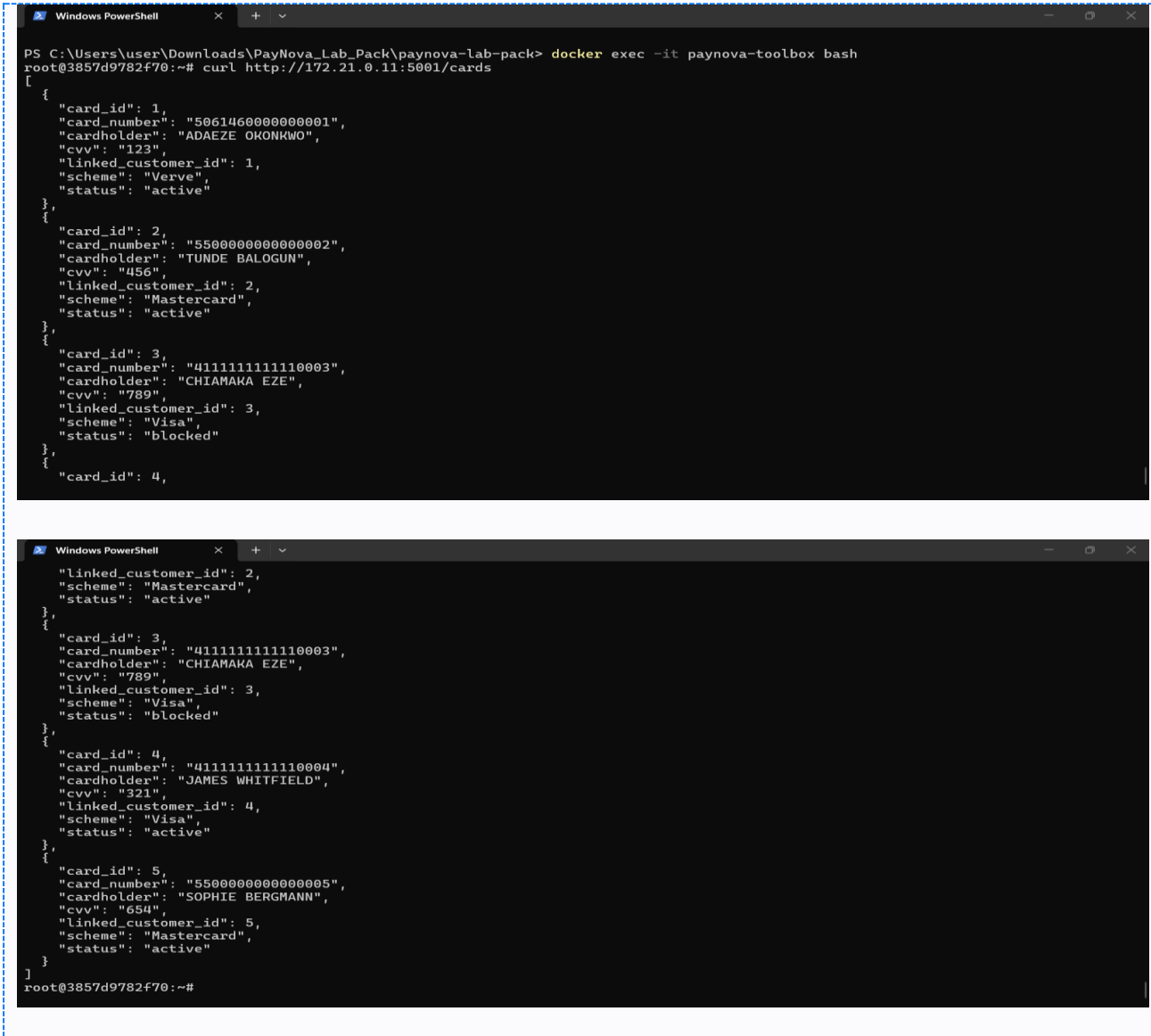
Executive summary

During security testing of the PayNova Card Scheme API, the /cards endpoint was found to return the complete card database without requiring authentication or authorisation. A single unauthenticated curl request from the PayNova toolbox returned multiple card records containing full PANs, CVVs, cardholder names, card IDs, linked customer IDs, card status, and card scheme. The finding is particularly severe because an unauthenticated user

can enumerate the entire collection rather than being restricted to cards belonging to an authorised customer.

Evidence

The following request was executed from the authorised PayNova lab toolbox: `curl http://172.21.0.11:5001/cards`. The API returned card records with structure similar to: `{"card_id": 1, "card_number": "5061460000000001", "cardholder": "ADAEZE OKONKWO", "cvv": "123", "linked_customer_id": 1, "scheme": "Verve", "status": "active"}`. The response contained five card records.



```
PS C:\Users\user\Downloads\PayNova_Lab_Pack\paynova-lab-pack> docker exec -it paynova-toolbox bash
root@3857d9782f70:~# curl http://172.21.0.11:5001/cards
[
  {
    "card_id": 1,
    "card_number": "5061460000000001",
    "cardholder": "ADAEZE OKONKWO",
    "cvv": "123",
    "linked_customer_id": 1,
    "scheme": "Verve",
    "status": "active"
  },
  {
    "card_id": 2,
    "card_number": "5500000000000002",
    "cardholder": "TUNDE BALOGUN",
    "cvv": "456",
    "linked_customer_id": 2,
    "scheme": "Mastercard",
    "status": "active"
  },
  {
    "card_id": 3,
    "card_number": "4111111111110003",
    "cardholder": "CHIAMA EZE",
    "cvv": "789",
    "linked_customer_id": 3,
    "scheme": "Visa",
    "status": "blocked"
  },
  {
    "card_id": 4,
    "linked_customer_id": 2,
    "scheme": "Mastercard",
    "status": "active"
  },
  {
    "card_id": 3,
    "card_number": "4111111111110003",
    "cardholder": "CHIAMA EZE",
    "cvv": "789",
    "linked_customer_id": 3,
    "scheme": "Visa",
    "status": "blocked"
  },
  {
    "card_id": 4,
    "card_number": "4111111111110004",
    "cardholder": "JAMES WHITFIELD",
    "cvv": "321",
    "linked_customer_id": 4,
    "scheme": "Visa",
    "status": "active"
  },
  {
    "card_id": 5,
    "card_number": "5500000000000005",
    "cardholder": "SOPHIE BERGMANN",
    "cvv": "654",
    "linked_customer_id": 5,
    "scheme": "Mastercard",
    "status": "active"
  }
]
```

Figure 28. Terminal screenshot showing `curl http://172.21.0.11:5001/cards` from the `paynova-toolbox` container and the JSON response containing multiple card records with full PANs and CVVs.

Root cause

Inspection of the Card Scheme API source code confirms the vulnerability. The route `@app.route("/cards", methods=["GET"]) def list_cards() returns jsonify(list(CARDS.values()))` with no authentication check, no role check, no ownership check, and no field-level filtering. The route returns the entire CARDS collection with all sensitive properties. The project's own source comments identify the endpoint as an intentional 'Broken Function Level Authorization' training vulnerability.

Attack scenario

An attacker who can reach the Card Scheme API does not need to authenticate. Step 1: discover the API (`curl http://172.21.0.11:5001/health`). Step 2: request the card collection (`curl http://172.21.0.11:5001/cards`). Step 3: receive the entire collection. No Authorization header, session, customer identifier, or administrative role is required.

Impact

If this weakness existed in a real payment environment, an unauthorised attacker could retrieve sensitive payment-card information at scale. The combination of full PAN + CVV + cardholder information substantially increases the sensitivity of the exposed dataset. Storage and disclosure of CVV in an API response is itself a direct PCI DSS v4.0.1 Requirement 3.3 violation — SAD (which includes CVV) must not be retained after authorisation, ever, and must not be transmitted through ordinary APIs. In this laboratory the records are deliberately seeded training data and should not be treated as real payment-card information; the finding would be identical against production data.

Recommended remediation

- Require authentication on the `/cards` endpoint (`Authorization: Bearer <token>`).
- Enforce role-based authorisation — for example, only service accounts with the 'card-admin' role may access card-management functionality.
- Enforce object-level authorisation — a caller should only retrieve cards they are explicitly authorised to access.
- Remove sensitive fields — the API should never return CVV. Full PAN should not be returned unless there is a specific, justified business requirement and appropriate controls. Return masked PAN (e.g. '*****0001') by default.
- Implement rate limiting to prevent automated enumeration.
- Implement logging and monitoring for requests to sensitive card-management endpoints (excessive requests, enumeration patterns, failed authorisation attempts, unusual source addresses, access outside expected service accounts).

- Eliminate CVV from the underlying data store entirely (PCI DSS 3.3).

7.2 Debug Configuration and Sensitive Information Disclosure

Finding ID	PAYNOVA-INFO-001
Category	Information Disclosure / Security Misconfiguration
OWASP API Security	API8:2023 — Security Misconfiguration; API9:2023 — Improper Inventory Management
Affected component	PayNova Card Scheme API
Affected endpoint	GET /debug/config
Affected host	172.21.0.11:5001
Severity	High
Authentication required	No
Status	Confirmed

Description

The PayNova Card Scheme API exposes a /debug/config endpoint that is accessible without authentication. The endpoint returns internal application configuration and environment information that should not be exposed to an API consumer, including the application's JWT signing secret. The endpoint's own response body includes the note 'This endpoint should not exist in any deployed environment.'

Evidence

GET /debug/config against 172.21.0.11:5001 returned a JSON body including environment variables (PYTHON_VERSION, WERKZEUG_RUN_MAIN, WERKZEUG_SERVER_FD), the JWT signing secret (redacted in this report), and the developer's own warning note. The actual JWT secret is retained only in the restricted lab evidence pack and is redacted from this report body.

```
]
root@3857d9782f70:~# curl http://172.21.0.11:5001/debug/config
{
  "env": {
    "GPG_KEY": "A035C8C19219BA821ECEA86B64E628F8D684696D",
    "HOME": "/root",
    "HOSTNAME": "a2b4571e48d2",
    "LANG": "C.UTF-8",
    "PATH": "/usr/local/bin:/usr/local/sbin:/usr/sbin:/usr/bin:/sbin:/bin",
    "PYTHON_SHA256": "91bcdebfdde239a003ae93738a7fce0f9230fee5c4bc2b86f6e6e8c6f98aabe8",
    "PYTHON_VERSION": "3.11.16",
    "WERKZEUG_RUN_MAIN": "true",
    "WERKZEUG_SERVER_FD": "6"
  },
  "jwt_secret": "paynova-cardscheme-secret",
  "note": "This endpoint should not exist in any deployed environment."
}
```

Figure 29. Terminal or Burp screenshot showing the GET /debug/config request and the JSON response containing environment variables and the JWT signing secret.

Root cause

The application contains an intentionally-exposed debug endpoint:

@app.route("/debug/config", methods=["GET"]) def debug_config() returns jsonify(jwt_secret=JWT_SECRET, env=dict(os.environ), note="..."). The application is also configured with app.run(host="0.0.0.0", port=5001, debug=True), running the Werkzeug development server with the debug flag enabled — which additionally enables the interactive Werkzeug debugger, itself a well-known RCE vector when reachable.

Impact

An attacker able to reach this endpoint can obtain sensitive internal information about the application environment. Exposure of the JWT signing secret is particularly significant because the application uses the secret to sign authentication tokens: an attacker with the signing secret can forge valid tokens for any user, including administrative users, defeating authentication entirely. The endpoint also exposes implementation details that assist further reconnaissance.

Recommended remediation

- Remove /debug/config from deployed applications; it must not exist outside a developer's local environment.
- Disable Flask/Werkzeug debug mode in any deployed environment (never run with debug=True except on developer workstations).
- Never expose secrets through HTTP responses under any circumstances.
- Store JWT signing secrets in a secure secrets-management mechanism (e.g. AWS Secrets Manager, HashiCorp Vault) rather than environment variables read by the application at start-up.
- Rotate the exposed JWT secret immediately and invalidate all outstanding tokens.

- Restrict administrative/debug endpoints through authentication and authorisation controls as defence in depth.
- Review the application for other endpoints that expose environment variables or internal configuration.
- Migrate the API from Werkzeug (development server) to a production WSGI server (Gunicorn or uWSGI) fronted by a hardened reverse proxy.

8. Database Security

This section reports the findings raised during database security testing against paynova-db (MySQL 8.0.46, 172.21.0.10, Payment network). Testing was performed from the paynova-toolbox container via authenticated MySQL client sessions and SQL enumeration; no destructive operations (DROP, TRUNCATE, DELETE) were executed against production data.

8.1 Remote MySQL Root Account with Excessive Privileges

Finding ID	F-DB-001
Category	Access Control / Privileged Access
Affected component	paynova-db (MySQL 8.0.46) – root@'%' account
Severity	Critical
Authentication required	Yes (credentials required, but any host)
Status	Confirmed

Description

The MySQL server contains a root account with a wildcard host mask (root@'%) that accepts authentication from any host matching % and possesses global administrative privileges. Authenticated testing from paynova-toolbox (172.21.0.99, Payment network) confirmed successful remote root authentication. SHOW GRANTS confirmed the account has SELECT, INSERT, UPDATE, DELETE, CREATE, DROP, ALTER, EXECUTE, CREATE USER, GRANT OPTION and further MySQL administrative privileges on *.* – full DDL, DML, and privilege-management control over every database on the server.

Evidence sighted

- SELECT USER(), CURRENT_USER() returned 'root@172.21.0.99 / root@%' from the paynova-toolbox client.
- mysql.user enumeration identified three accounts: paynova_app@%, paynova_readonly@%, root@%.
- SHOW GRANTS FOR 'root'@'%' returned GRANT ALL PRIVILEGES ON *.* WITH GRANT OPTION.
- The initial unauthenticated attempt (mysql -h 172.21.0.10 -u root without password) was rejected with 'Access denied (using password: NO)' – authentication is enforced (this is not a bypass).

```

root@3857d9782f70:~# ldapsearch -N -Y GSSAPI -H ldap://paynova-dc.paynova.local \
-b 'DC=paynova,DC=local' \
'(&(objectClass=group)(member=*))' \
sAMAccountName member
SASL/GSSAPI authentication started
SASL username: Administrator@PAYNOVA.LOCAL
SASL SSF: 256
SASL data security layer installed.
# extended LDIF
#
# LDAPv3
# base <DC=paynova,DC=local> with scope subtree
# filter: (&(objectClass=group)(member=*))
# requesting: sAMAccountName member
#
# Windows Authorization Access Group, Builtin, paynova.local
dn: CN=Windows Authorization Access Group,CN=Builtin,DC=paynova,DC=local
member: CN=S-1-5-9,CN=ForeignSecurityPrincipals,DC=paynova,DC=local
sAMAccountName: Windows Authorization Access Group
# Users, Builtin, paynova.local
dn: CN=Users,CN=Builtin,DC=paynova,DC=local
member: CN=S-1-5-11,CN=ForeignSecurityPrincipals,DC=paynova,DC=local
member: CN=Domain Users,CN=Users,DC=paynova,DC=local
member: CN=S-1-5-4,CN=ForeignSecurityPrincipals,DC=paynova,DC=local
sAMAccountName: Users
# Pre-Windows 2000 Compatible Access, Builtin, paynova.local
dn: CN=Pre-Windows 2000 Compatible Access,CN=Builtin,DC=paynova,DC=local
member: CN=S-1-5-11,CN=ForeignSecurityPrincipals,DC=paynova,DC=local

```

```

sAMAccountName: Pre-Windows 2000 Compatible Access
# IIS_IUSRS, Builtin, paynova.local
dn: CN=IIS_IUSRS,CN=Builtin,DC=paynova,DC=local
member: CN=S-1-5-17,CN=ForeignSecurityPrincipals,DC=paynova,DC=local
sAMAccountName: IIS_IUSRS
# Enterprise Admins, Users, paynova.local
dn: CN=Enterprise Admins,CN=Users,DC=paynova,DC=local
member: CN=Administrator,CN=Users,DC=paynova,DC=local
sAMAccountName: Enterprise Admins
# Administrators, Builtin, paynova.local
dn: CN=Administrators,CN=Builtin,DC=paynova,DC=local
member: CN=Enterprise Admins,CN=Users,DC=paynova,DC=local
member: CN=Domain Admins,CN=Users,DC=paynova,DC=local
member: CN=Administrator,CN=Users,DC=paynova,DC=local
sAMAccountName: Administrators
# Denied RODC Password Replication Group, Users, paynova.local
dn: CN=Denied RODC Password Replication Group,CN=Users,DC=paynova,DC=local
member: CN=Read-only Domain Controllers,CN=Users,DC=paynova,DC=local
member: CN=krbtgt,CN=Users,DC=paynova,DC=local
member: CN=Cert Publishers,CN=Users,DC=paynova,DC=local
member: CN=Domain Controllers,CN=Users,DC=paynova,DC=local
member: CN=Enterprise Admins,CN=Users,DC=paynova,DC=local
member: CN=Domain Admins,CN=Users,DC=paynova,DC=local
member: CN=Group Policy Creator Owners,CN=Users,DC=paynova,DC=local
member: CN=Schema Admins,CN=Users,DC=paynova,DC=local
sAMAccountName: Denied RODC Password Replication Group
# Guests, Builtin, paynova.local
dn: CN=Guests,CN=Builtin,DC=paynova,DC=local

```

```

member: CN=Guest,CN=Users,DC=paynova,DC=local
member: CN=Domain Guests,CN=Users,DC=paynova,DC=local
sAMAccountName: Guests

# Domain Admins, Users, paynova.local
dn: CN=Domain Admins,CN=Users,DC=paynova,DC=local
member: CN=Administrator,CN=Users,DC=paynova,DC=local
sAMAccountName: Domain Admins

# Group Policy Creator Owners, Users, paynova.local
dn: CN=Group Policy Creator Owners,CN=Users,DC=paynova,DC=local
member: CN=Administrator,CN=Users,DC=paynova,DC=local
sAMAccountName: Group Policy Creator Owners

# Schema Admins, Users, paynova.local
dn: CN=Schema Admins,CN=Users,DC=paynova,DC=local
member: CN=Administrator,CN=Users,DC=paynova,DC=local
sAMAccountName: Schema Admins

# search reference
ref: ldap://paynova.local/CN=Configuration,DC=paynova,DC=local

# search reference
ref: ldap://paynova.local/DC=DomainDnsZones,DC=paynova,DC=local

# search reference
ref: ldap://paynova.local/DC=ForestDnsZones,DC=paynova,DC=local

# search result
search: 4
result: 0 Success

# numResponses: 15

# search result
search: 4
result: 0 Success

# numResponses: 15
# numEntries: 11
# numReferences: 3
root@3857d9782f70:~#

```

Figure 30. Terminal screenshot showing successful root authentication from paynova-toolbox, USER()/CURRENT_USER() output, mysql.user enumeration, and SHOW GRANTS output.

Impact

Compromise of the root credential from any host with network reach to the Payment segment provides total database compromise — read, modify, delete any record; create or modify accounts; grant privileges to other accounts; alter schema; execute privileged administrative operations. In combination with F-NET-002 (DMZ–Payment reachability), this means compromise of the customer-facing web tier plus knowledge of the root credential is sufficient for total cardholder-data-environment compromise.

Recommended remediation

- P0 — Remove root@'%' immediately. Rotate the root credential during the change.
- Restrict administrative accounts to localhost or specific administrative jump hosts (root@'127.0.0.1', root@'admin-jumphost.internal').
- Move to a jump-host model for privileged database access with MFA enforced at the jump host.

- Restrict paynova_app and paynova_readonly by source host in the account definition where the deployment allows (e.g. paynova_app@'172.20.0.20').
- Enable general_log or audit_log to record all connection attempts and DDL/DCL statements; forward to SIEM (see R-026).

8.2 Sensitive Payment Card Data (PAN + CVV) Stored in Database

Finding ID	F-DB-002
Category	Data Protection / PCI DSS Requirement 3.3 violation
Affected component	paynova.cards table
Severity	Critical
Status	Confirmed

Description

The paynova.cards table stores sensitive payment-card information including card_number (VARCHAR(19)), cardholder_name (VARCHAR(120)), expiry_month (TINYINT), expiry_year (SMALLINT), and cvv (CHAR(3)). Database enumeration confirmed that all 5 sampled records contained both a card_number and a cvv value. The schema shows no database-level encryption, tokenisation, or field-level protection for these columns. Storage of CVV values is prohibited by PCI DSS v4.0.1 Requirement 3.3 under any circumstances after authorisation — this finding is a direct PCI DSS violation independent of any subsequent exposure vector.

Evidence sighted

- DESCRIBE cards — schema confirms card_number VARCHAR(19), cardholder_name VARCHAR(120), expiry_month TINYINT, expiry_year SMALLINT, cvv CHAR(3).
- SELECT COUNT(*) FROM cards WHERE card_number IS NOT NULL AND cvv IS NOT NULL returned 5 of 5 records.
- Masked SELECT (using LEFT/RIGHT concatenation to redact middle digits) confirmed populated card records with realistic PAN structure without exposing complete PANs/CVV in evidence.

- This finding is the storage-layer manifestation of the same data class exposed at the web tier via PN-WEB-001 (customer backup CSV) and at the API tier via PAYNOVA-API-001 (unauthenticated /cards endpoint).

```
MySQL [paynova]> SELECT
->   COUNT(*) AS total_cards,
->   COUNT(card_number) AS cards_with_number,
->   COUNT(cvv) AS cards_with_cvv
-> FROM cards;
+-----+-----+-----+
| total_cards | cards_with_number | cards_with_cvv |
+-----+-----+-----+
|          5 |                5 |                5 |
+-----+-----+-----+
1 row in set (0.047 sec)

MySQL [paynova]> SELECT
->   card_id,
->   customer_id,
->   CONCAT(LEFT(card_number,4), '*****', RIGHT(card_number,4)) AS masked_card,
->   cardholder_name,
->   expiry_month,
->   expiry_year,
->   status
-> FROM cards
-> LIMIT 5;
+-----+-----+-----+-----+-----+-----+-----+
| card_id | customer_id | masked_card | cardholder_name | expiry_month | expiry_year | status |
+-----+-----+-----+-----+-----+-----+-----+
|        1 |           1 | 5061*****0001 | ADAEZE OKONKWO |          9 |         2027 | active |
|        2 |           2 | 5500*****0002 | TUNDE BALOGUN |          3 |         2026 | active |
|        3 |           3 | 4111*****0003 | CHIAMAKA EZE |         11 |         2028 | blocked |
|        4 |           4 | 4111*****0004 | JAMES WHITFIELD |          5 |         2027 | active |
|        5 |           5 | 5500*****0005 | SOPHIE BERGMANN |          8 |         2026 | active |
+-----+-----+-----+-----+-----+-----+-----+
```

Figure 31. MySQL client screenshot showing DESCRIBE cards output and the masked SELECT confirming 5/5 records contain PAN + CVV. Note: card_number, cvv columns to be masked before inclusion in any distributed copy of this evidence.

Impact

Storage of CVV after authorisation is a fundamental PCI DSS violation and would be identified by any QSA assessment as a Report-on-Compliance failure. It also materially increases the impact of any database compromise: full PAN + CVV + cardholder name is the primary card-not-present fraud dataset, and its exposure at scale (all cards, not one) is what turns a database incident into a mass card-fraud event.

Recommended remediation

- P0 – Immediate: eliminate the cvv column from the cards table entirely. CVV values must not be persisted after authorisation. This requires (a) application changes to validate CVV at authorisation time and discard, (b) schema migration to drop the column, (c) confirmation via audit that no historical backups retain CVV values.
- Tokenise PAN using a compliant tokenisation service or vault. Only the tokenisation service should hold the mapping between token and PAN.

- For any PAN retained (e.g. last-4 for customer display), store only the truncated form; render unreadable per PCI DSS Req 3.5.
- Apply strong encryption for any residual cardholder data at rest, with the key stored in a dedicated key-management service.
- Review all backups, logs, exports, replicas, and non-production copies for CVV; purge any historical CVV data.
- Commission a PCI DSS gap assessment as part of the P1 remediation plan.

8.3 Sensitive Customer PII Stored in Cleartext

Finding ID	F-DB-003
Category	Data Protection / Privacy
Affected component	paynova.customers table
Severity	High
Status	Confirmed

Description

The paynova.customers table stores sensitive customer PII in cleartext columns: full_name, email, phone, national_id, date_of_birth, residency, plus password_hash. Testing across all 6 sampled records confirmed values are populated in national_id, date_of_birth, password_hash, and phone. National ID and date of birth together are sufficient for identity-related fraud; combined with the exposed password_hash (see F-DB-005 for the algorithm weakness), the record set is sufficient to compromise a customer's account and to impersonate them at KYC.

Evidence sighted

- DESCRIBE customers — schema confirms all fields as ordinary character/date columns; no encryption at column level.
- SELECT COUNT(*) with IS NOT NULL predicates returned 6 of 6 records populated in national_id, date_of_birth, password_hash, phone.
- Masked SELECT returned customer names, masked contact and identifier data, dates of birth, residency, and administrative status — confirming the values are readable to any holder of the database credential.

```

1 row in set (0.010 sec)

MySQL [paynova]> SELECT
->   customer_id,
->   full_name,
->   CONCAT(LEFT(email,2),'***@***') AS masked_email,
->   CONCAT('***',RIGHT(phone,4)) AS masked_phone,
->   CONCAT('***',RIGHT(national_id,2)) AS masked_national_id,
->   date_of_birth,
->   residency_country,
->   is_admin
-> FROM customers
-> LIMIT 5;
+-----+-----+-----+-----+-----+-----+-----+
| customer_id | full_name      | masked_email | masked_phone | masked_national_id | date_of_birth | residency_country |
| is_admin   |
+-----+-----+-----+-----+-----+-----+-----+
| 0 | 1 | Adaeze Okonkwo | ad***@*** | ***2222 | ***01 | 1985-03-12 | NG |
| 0 | 2 | Tunde Balogun  | tu***@*** | ***3333 | ***02 | 1990-07-01 | NG |
| 0 | 3 | Chiamaka Eze   | ch***@*** | ***4444 | ***03 | 1992-11-15 | NG |
| 0 | 4 | James Whitfield | ja***@*** | ***3344 | ***04 | 1988-12-04 | GB |
| 0 | 5 | Sophie Bergmann | so***@*** | ***3344 | ***05 | 1995-06-30 | DE |
+-----+-----+-----+-----+-----+-----+-----+

```

Figure 32. MySQL client screenshot showing the customers table structure and a masked SELECT of the 6 records.

Impact

Compromise of the database credential (see F-DB-001) or of any account authorised to read the customers table exposes complete PII for the customer base. Under NDPA 2023, GDPR Article 33, and UK GDPR Article 33 this would trigger regulator notification within 72 hours if the customer set includes EU/UK data subjects (which the assessment sample confirms — see PIA §1.3).

Recommended remediation

- Apply column-level encryption to national_id and date_of_birth; hold keys in a KMS separate from the database.
- Minimise stored PII — retain only what is necessary for the documented processing purposes.
- Restrict database connectivity to authorised application service accounts, source-host-restricted (see F-DB-001).
- Enable database audit logging for reads of the customers table; forward to SIEM.
- Apply the DSAR/erasure workflow (PIA PR-08 / R-035) to allow customers to exercise their statutory rights against this data.

8.4 Excessive Database Privileges on Application Account

Finding ID	F-DB-004
Category	Access Control / Least Privilege
Affected component	paynova_app account on paynova-db
Severity	High
Status	Confirmed

Description

The paynova_app database account holds ALL PRIVILEGES on the entire paynova database: GRANT ALL PRIVILEGES ON `paynova`.* TO `paynova\_app`@`%`. This grants broad administrative capabilities (SELECT/INSERT/UPDATE/DELETE plus DDL such as DROP, CREATE, ALTER and privilege-management such as GRANT) over every table in the paynova schema, rather than the minimum operations the application actually requires. If paynova_app credentials are recovered via any application-tier vulnerability — SQL injection (WEB-SQLI-001), debug endpoint disclosure (PAYNOVA-INFO-001), or source-code exposure — the attacker gains DDL and DML control across the entire schema.

Positive contrast

The paynova_readonly account is correctly restricted to SELECT only (GRANT SELECT ON `paynova`.* TO `paynova\_readonly`@`%`). This is the pattern paynova_app should follow.

```
MySQL [paynova]> SHOW GRANTS FOR 'paynova_app'@'%';
+-----+
| Grants for paynova_app@% |
+-----+
| GRANT USAGE ON *.* TO `paynova_app`@`%` |
| GRANT ALL PRIVILEGES ON `paynova`.* TO `paynova_app`@`%` |
+-----+
2 rows in set (0.006 sec)

MySQL [paynova]> SHOW GRANTS FOR 'paynova_readonly'@'%';
+-----+
| Grants for paynova_readonly@% |
+-----+
| GRANT USAGE ON *.* TO `paynova_readonly`@`%` |
| GRANT SELECT ON `paynova`.* TO `paynova_readonly`@`%` |
+-----+
2 rows in set (0.001 sec)
```

Figure 33. MySQL client screenshot showing SHOW GRANTS FOR 'paynova_app'@`%` and SHOW GRANTS FOR 'paynova_readonly'@`%` side by side.

Impact

Elevation of any application-tier compromise to full schema control. SQL-injection findings that would ordinarily allow read-only exfiltration would, against this account, additionally enable data modification, account creation, and privilege escalation.

Recommended remediation

- Apply least privilege to paynova_app. Grant only the specific SELECT, INSERT, UPDATE, and DELETE permissions on the specific tables the application requires.
- Do not grant DROP, CREATE, ALTER, GRANT OPTION or other privilege-management capabilities to application accounts.
- Restrict the account by source host where the application deployment permits (paynova_app@'172.20.0.20' rather than @'%').
- Review all other application accounts against the same principle.
- Where the application requires DDL (schema migrations), use a separate migration-only account executed only during change windows.

8.5 Weak Password Hashing Algorithm (MD5)

Finding ID	F-DB-005
Category	Cryptography / Authentication
Affected component	paynova.customers.password_hash
Severity	High
Status	Confirmed

Description

The paynova.customers table stores password_hash values as 32-character hexadecimal strings — the signature of MD5. Testing across all 6 sampled records confirmed a hash_length of exactly 32 with hex-only content (SELECT LENGTH(password_hash) FROM customers returned 32 for every record). No per-user salt is visible in the stored representation. MD5 is unsuitable for password storage: it is fast (allowing very-high-rate offline cracking), has known collisions, and precomputed rainbow tables cover much of the plausible password space.

Evidence sighted

- SELECT LENGTH(password_hash), COUNT(*) FROM customers GROUP BY LENGTH(password_hash) returned a single row: length=32, count=6.

- SELECT password_hash sample returned values of the form '42f749ade7f9e195bf47...', 'b56e0b4ea4962283bee7...', '47b7bf65fa83ac9a71d...' — hexadecimal, 32 chars, no observable per-user salt prefix.
- The customers table password_hash column is populated in all 6 sampled records.

```
mysql> USE paynova;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> SELECT customer_id, LENGTH(password_hash) AS hash_length,
-> LEFT(password_hash, 20) AS hash_prefix
-> FROM customers;
```

customer_id	hash_length	hash_prefix
1	32	42f749ade7f9e195bf47
2	32	b56e0b4ea4962283bee7
3	32	47b7bf65fa83ac9a71d
4	32	4cb9c8a8048fd0229447
5	32	4cb9c8a8048fd0229447
6	32	0e7517141fb53f21ee43

```
6 rows in set (0.00 sec)

mysql> |
```

Figure 34. MySQL client screenshot showing SELECT LENGTH(password_hash), COUNT(*) result and a masked sample of hash values (only length and character-class should be visible in evidence) — screenshot to be attached in a subsequent iteration.

Impact

If the customers table is exfiltrated — via any of F-DB-001 (remote root), F-DB-004 (application account compromise), PN-WEB-001 (backup exposure), or any future application vulnerability — user passwords are recoverable at low cost. Password reuse (empirically common) means the same credentials will unlock third-party accounts, extending the impact beyond PayNova.

Recommended remediation

- Migrate to Argon2id (preferred, RFC 9106), bcrypt, scrypt, or PBKDF2 with a strong work factor.
- Generate a unique cryptographic salt per user using the password-hashing library (never a manual random_bytes call).
- Migration approach: on next login, verify against the stored MD5 hash and, on success, re-hash the plaintext with Argon2id and store. Track migration progress; after a defined window, force reset for accounts still on MD5.
- Add CI/CD tests that reject MD5-format hashes.
- Combine with the weak-password-policy remediation (F-AD-002) — a modern hash algorithm with a 7-character minimum length is still vulnerable to brute force.

9. Negative Test Results (No Vulnerability Observed)

This section records security tests that were executed and did not produce a vulnerability. Recording negative results is important for audit assurance: it demonstrates that the assessment considered the attack class and confirms the coverage of testing. A negative result does not prove the class of vulnerability is absent from the entire environment — it only establishes that the specific tested paths did not exhibit the vulnerability during the testing window.

9.1 Backup File Exposure — Card Scheme API

Test ID	PAYNOVA-TEST-001
Category	Information Disclosure Testing
Test type	Negative test
Affected component	PayNova Card Scheme API
Affected host	172.21.0.11:5001
Status	No Vulnerability Observed

Objective

Determine whether the PayNova Card Scheme API exposes common application backup files, archived source code, or backup directories through HTTP.

Methodology

The following commonly-used backup and archive paths were tested using a shell loop issuing curl requests: /app.py.bak, /app.py.backup, /app.py.old, /app.py~, /backup, /backups, /backup.zip, /app.zip. Each request recorded only the HTTP status code.

Command executed:

```
for p in /app.py.bak /app.py.backup /app.py.old /app.py~ /backup /backups /backup.zip /app.zip; do echo "==== $p ====="; curl -s -o /dev/null -w "%{http_code}\n" "http://172.21.0.11:5001$p"; done
```

Results

All tested paths returned HTTP 404.

Resource Tested	HTTP Status	Result
/app.py.bak	404	Not exposed
/app.py.backup	404	Not exposed
/app.py.old	404	Not exposed
/app.py~	404	Not exposed
/backup	404	Not exposed
/backups	404	Not exposed
/backup.zip	404	Not exposed
/app.zip	404	Not exposed

```

root@3857d9782f70:~# for p in /app.py.bak /app.py.backup /app.py.old /app.py~ /backup /backups /backup.zip /app.zip; do
  echo "==== $p ====="
  curl -s -o /dev/null -w "%{http_code}\n" "http://172.21.0.11:5001$p"
done
==== /app.py.bak =====
404
==== /app.py.backup =====
404
==== /app.py.old =====
404
==== /app.py~ =====
404
==== /backup =====
404
==== /backups =====
404
==== /backup.zip =====
404
==== /app.zip =====
404
root@3857d9782f70:~#

```

Figure 35. Terminal screenshot showing the backup-file enumeration script running and all eight tested paths returning HTTP.

Assessment

No backup-file exposure was identified through the tested paths on the Card Scheme API. This test does not prove that no backup files exist anywhere in the application; it only establishes that the tested common paths were not accessible through the tested HTTP interface. Note: the customer-facing PayNova portal (a different service, on TCP/8080) does expose a /backups/ directory containing a customer backup – reported as PN-WEB-001 in Section 6.1. The two results are not contradictory: they apply to different services.

Recommendation (defence-in-depth)

- Continue to ensure source-code backups are not stored inside web-accessible directories.
- Exclude .bak, .old, .backup, ~, and archive files from deployments.
- Configure web servers to deny access to backup and temporary file extensions.
- CI/CD pipelines should prevent accidental deployment of development artefacts.

9.2 Command Injection Source-Code Review

Test ID	PAYNOVA-TEST-CMD-001
Category	Injection Testing (Source-Code Review)
Test type	Negative test
Affected components	paynova-creditbureau-api and paynova-cardscheme-api
Status	No Vulnerability Observed

Method

Reviewed /app/app.py for common OS command-execution mechanisms including os.system, subprocess, shell=True, and related command-execution patterns.

Result

No matching patterns were identified in the reviewed source files.

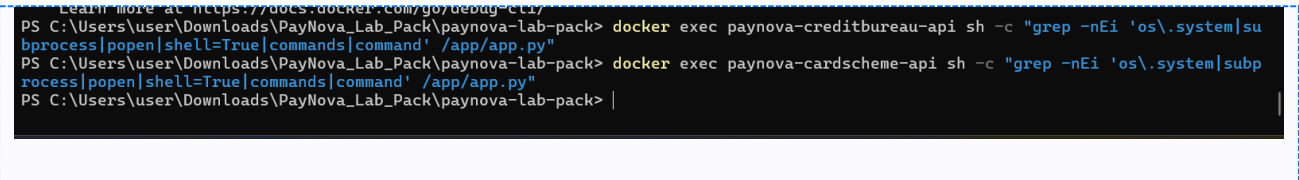


Figure 36. Terminal screenshot showing the grep commands executed against /app/app.py and their empty output (no matches).

Conclusion

Command injection was not observed during this source-code review. The review was limited to obvious command-execution patterns; a dynamic testing pass and a wider review of any newly-added code paths should be performed as part of routine change assurance.

9.3 Stack Trace Disclosure

Test ID	PAYNOVA-TEST-002
Category	Information Disclosure Testing
Test type	Negative test
Affected component	PayNova Card Scheme API
Status	No Vulnerability Observed

Method

Malformed input was submitted to the Card Scheme API endpoints (invalid JSON, unexpected content types, oversized payloads) to elicit a stack trace or unhandled-exception disclosure.

Result

No stack traces or unhandled-exception output were observed in the response bodies during this testing window. The application returned generic error responses (HTTP 400 / 404 / 405) for the malformed inputs tested.

```
root@3857d9782f70:~# ldapsearch -x -H ldap://172.22.0.10 -b "DC=paynova,DC=local" -s base "(objectClass=*)" dn
# extended LDIF
#
# LDAPv3
# base <DC=paynova,DC=local> with scope baseObject
# filter: (objectClass=*)
# requesting: dn
#
# search result
search: 2
result: 1 Operations error
text: 00002020: Operation unavailable without authentication

# numResponses: 1
root@3857d9782f70:~#
```

Figure 37. Terminal screenshot showing malformed requests to the Card Scheme API and the generic error responses without stack-trace disclosure.

Conclusion

Stack trace disclosure was not observed. Note that the Werkzeug development server (see F-NET-005 and PAYNOVA-INFO-001) can expose an interactive debugger — including full stack traces and code execution — when debug=True is set. That risk is captured under PAYNOVA-INFO-001; the negative result here relates only to ordinary error responses.

10. Summary of Findings

10.1 Risk-Rating Scheme (Reference)

The following scheme is applied uniformly across every deliverable in this engagement (this report, the Risk Register, the Privacy Impact Assessment, and the Incident Response Plan).

This section is the authoritative reference; the other deliverables inherit it.

Scoring

Likelihood is rated 1 (Rare) to 5 (Almost Certain). Impact is rated 1 (Insignificant) to 5 (Catastrophic). Inherent Risk Score = Likelihood × Impact, on a 1–25 scale.

Rating bands

Rating	Score	Meaning	Response expectation
Critical	21–25	Direct exposure of regulated data, or full compromise likely with minimal skill.	Emergency response (P0). Treat as an in-flight incident.
High	13–20	Significant business or compliance impact; exploitation realistic with a clear attack path.	Priority remediation (P1) within 30 days.
Medium	7–12	Meaningful weakness that reduces security posture but requires additional conditions to exploit.	Planned remediation (P2) within 90 days.
Low	1–6	Limited impact in isolation; typically hygiene or hardening.	Continuous improvement (P3–P4); accept or plan for a later cycle.
Info	—	Observation with no direct security impact.	Noted for awareness or context.

Positive	—	Existing control observed to be operating as intended.	Documented for completeness; revalidate annually.
Not Observed	—	Attack class tested; no vulnerability found in the tested paths.	Documented as coverage; not assurance.

Colour palette

Two palettes are used, keyed to the same rating labels: light pastel fills for table cells (below), and saturated versions for chart bars, badges, and executive callouts (see Executive Briefing).

Rating	Table cell fill (hex)	Chart / badge fill (hex)	Where used
Critical	F5B7B1	C0392B	Cell fills in this report, Register, PIA, IRP; chart bars in the Executive Briefing
High	FAD7A0	E67E22	As above
Medium	FCE5A0	F1C40F	As above
Low	D5F5E3	27AE60	As above
Info	E8ECEF	7F8C8D	Assessment Report; Executive Briefing (grey)
Positive	D4E7D3	16A085	Assessment Report positive controls; PPT check-cards
Not Observed	E8ECEF	95A5A6	§8 Negative Test Results

Note on the Incident Response Plan: the IRP uses SEV-1 / SEV-2 / SEV-3 as incident-severity labels (a standard IR concept distinct from risk severity). Those labels map to the same colour palette — SEV-1 to the Critical fill, SEV-2 to the High fill, SEV-3 to the Medium fill.

10.2 Finding Counts by Severity

Severity	Network (§3, §5)	AD/IAM (§4)	Web App (§6)	API (§7)	Database (§8)	Total
Critical	0	0	1	1	2	4
High	1	0	1	1	3	6
Medium	3	2	4	0	0	9
Low	3	0	1	0	0	4
Info	0	0	0	0	0	0
Positive	3	2	0	0	0	5
Not Observed	0	0	0	0	0	0

The Not Observed row shows zero here because the three negative tests (§9.1 – §9.3) all target the API layer and are recorded there.

10.3 Consolidated Finding Register

ID	Title	Severity	Section
F-NET-001	LDAP RootDSE information disclosure (revised — validation confirmed auth required for directory ops)	Low	§4.2.1
F-NET-002	Excessive DMZ-to-Payment network reachability	High	§5.1
F-NET-003	Sensitive application paths disclosed via robots.txt (validated as PN-WEB-001)	Medium	§3.1.1
F-NET-004	Unrestricted CORS configuration on customer web application	Medium	§3.1.2

F-NET-005	Payment APIs served by Werkzeug development server	Medium	§3.2.2
F-NET-006	MySQL database service network-discoverable across segments	Low	§3.2.1
F-NET-007	Technology stack and version disclosure across multiple services	Low	§3.4
F-AD-001	Anonymous SMB share enumeration on PAYNOVA-DC	Medium	§4.2.2
F-AD-002	Weak Active Directory password and account lockout policy	Medium	§4.2.3
P-NET-001	SMB message signing enabled and required on domain controller	Positive	§3.3.1
P-NET-002	DMZ-to-Corporate segmentation blocks tested AD services	Positive	§5.2
P-NET-003	Payment-to-Corporate segmentation blocks tested AD services	Positive	§5.3
P-AD-001	LDAP requires authentication for directory operations	Positive	§4.3
P-AD-002	SMB share content access denied for anonymous users	Positive	§4.3

PN-WEB-001	Unauthenticated exposure of customer backup (PANs, CVVs, PINs)	High	§6.1
WEB-SQLI-001	SQL injection – authentication bypass to administrator account	Critical	§6.2
PHIO-003	Broken Object-Level Authorization – unauthorised basket access	Medium	§6.3
WEB-BAC-001	Broken Access Control – admin application-configuration endpoint	Medium	§6.4
PHIO-004	DOM-based Cross-Site Scripting via search parameter	Medium	§6.5
FIND-008	Session token remains valid after logout	Medium	§6.6
WEB-INFO-001	Server version information disclosure (nginx/1.27.5)	Low	§6.7
PAYNOVA-API-001	Unauthenticated card data enumeration on GET /cards	Critical	§7.1
PAYNOVA-INFO-001	Debug configuration and JWT signing-secret disclosure	High	§7.2

F-DB-001	Remote MySQL root@'%' with excessive privileges	Critical	§8.1
F-DB-002	Sensitive payment card data (PAN + CVV) stored in database	Critical	§8.2
F-DB-003	Sensitive customer PII stored in cleartext	High	§8.3
F-DB-004	Excessive database privileges on paynova_app application account	High	§8.4
F-DB-005	Weak password hashing algorithm (MD5)	High	§8.5
PAYNOVA-TEST-001	Backup file exposure — Card Scheme API	Not Observed	§9.1
PAYNOVA-TEST-CMD-001	Command injection — source-code review	Not Observed	§9.2
PAYNOVA-TEST-002	Stack trace disclosure	Not Observed	§9.3

11. Compliance Mapping

The table below maps each confirmed finding to the primary control frameworks and regulatory requirements applicable to a Nigerian fintech environment. Privacy-specific mapping (NDPA s.24–s.40, GDPR Art. 6/13/22/32/33/34/35, UK GDPR equivalents) for each processing activity is covered in the Privacy Impact Assessment v1.0 §3 and §5; the six governance-level privacy risks raised in the PIA are tracked in the Risk Register v3 as R-035 to R-040.

Finding	ISO/IEC 27001:2022	PCI DSS v4.0.1	Other / regulatory
F-NET-001	A.5.15, A.8.9	2.2	OWASP LDAP hardening; CIS AD Benchmark
F-NET-002	A.8.20, A.8.22	1.2, 1.3, 1.4	CBN RBCF; NIST SP 800-41
F-NET-003	A.5.10, A.8.9	6.4	OWASP WSTG-INFO-06
F-NET-004	A.8.28	6.2.4	OWASP ASVS V14.5.3; OWASP API Top 10 API8
F-NET-005	A.8.9, A.8.27	2.2, 6.2	OWASP API Top 10 API8; CBN RBCF
F-NET-006	A.8.9, A.8.20	1.4, 2.2	CIS MySQL 8.0 Benchmark
F-NET-007	A.8.8, A.8.9	6.3, 6.3.3	OWASP ASVS V14.3
F-AD-001	A.5.15, A.8.9	2.2, 7.2	CBN RBCF; CIS Samba/AD Benchmark
F-AD-002	A.5.17, A.8.5	8.3, 8.4	CBN RBCF; CIS Windows Server Benchmark
PN-WEB-001	A.5.34, A.8.9, A.8.11, A.8.13	3.3, 3.5, 6.4, 7.2, 7.3	NDPA 2023; UK/EU GDPR Art. 5, 32, 33; OWASP Top 10 2021

			A01/A02/A05; CBN RBCF
WEB-SQLI-001	A.8.28, A.8.29	6.2.4, 8.3	OWASP Top 10 2021 A03; CWE-89; CBN RBCF
PHI0-003	A.5.15, A.8.3	7.2, 7.3	OWASP Top 10 2021 A01; OWASP API Top 10 API1; CWE-639
WEB-BAC-001	A.5.15, A.8.3	7.2, 7.3	OWASP Top 10 2021 A01; CWE-862
PHI0-004	A.8.28	6.2.4	OWASP Top 10 2021 A03; CWE-79
FIND-008	A.5.17, A.8.5	8.2, 8.6	OWASP Top 10 2021 A07; CWE-613
WEB-INFO-001	A.8.9	2.2	OWASP ASVS V14.3
PAYNOVA-API-001	A.5.15, A.5.34, A.8.3, A.8.11	3.3, 3.5, 6.4, 7.2, 8.3	NDPA 2023; UK/EU GDPR Art. 5, 32; OWASP API Top 10 API1/API3/API5; CWE-862/200/359
PAYNOVA-INFO-001	A.5.14, A.8.9, A.8.24	2.2, 3.7, 6.2, 8.6	OWASP API Top 10 API8/API9; CWE-798/532
F-DB-001	A.5.15, A.8.2, A.8.3	7.2, 8.2, 8.6	CBN RBCF — privileged access; CIS MySQL 8.0 Benchmark; CWE-798/284
F-DB-002	A.5.34, A.8.11, A.8.24	3.3, 3.5, 3.7	NDPA 2023; UK/EU GDPR Art. 32; PCI DSS 3.3 (SAD prohibition — fundamental)

F-DB-003	A.5.34, A.8.11, A.8.24	3.5, 3.7, 8.6	NDPA 2023 s.24; UK/EU GDPR Art. 5, 32; CBN RBCF
F-DB-004	A.5.15, A.8.2, A.8.3	7.2, 7.3	OWASP Top 10 2021 A01; CIS MySQL 8.0 Benchmark; CWE-269
F-DB-005	A.5.17, A.8.24	8.3.2, 8.3.5	OWASP ASVS V2.4; NIST SP 800-63B; CWE-916

12. Remediation Roadmap

The roadmap below prioritises confirmed findings by risk, time-frame, and indicative owner. The two P0 (Emergency) items should be treated as in-flight incidents rather than scheduled remediation. Incident-response readiness (previously carried as a gap under R-025 in the risk register) is now partially addressed by the PayNova Incident Response Plan v1.0; tabletop exercises and named-on-call staffing remain outstanding.

Priority	Timeframe	Finding(s)	Owner (indicative)	Outcome
P0 – Emergency	0–7 days	PN-WEB-001, PAYNOVA-API-001, WEB-SQLI-001, PAYNOVA-INFO-001, F-DB-001, F-DB-002	Web Engineering; API Platform; Database Team; DPO; Incident Response	Take /backups/ offline and delete exposed CSV; take /cards and /debug/config offline pending fix; remove MySQL root@'%' and rotate root credential; eliminate the cvv column from the cards table (PCI DSS 3.3 violation); rotate JWT secret and invalidate outstanding tokens; patch SQL-injection auth bypass; treat as suspected data breach and coordinate response

				through the Incident Response Plan v1.1 (which uses PN-WEB-001 as the worked example); execute NDPA/GDPR/UK GDPR notification obligations within the applicable windows (see IRP §7).
P1 – Immediate	0–30 days	F-NET-002, F-AD-002, PH10-003, WEB-BAC-001, FIND-008, F-DB-003, F-DB-004	Network; AD Administrator; Web Engineering; Database Team	Restrict DMZ-to-Payment reachability; fix AD password policy (lockoutThreshold, minPwdLength ≥ 12); add server-side object-level authorisation on basket and every other user-owned resource; enforce role checks on all administrative endpoints; implement server-side session/token revocation on

				logout; encrypt customer PII columns (national_id, date_of_birth) at rest; apply least privilege to paynova_app (remove ALL PRIVILEGES; grant only required DML on required tables).
P2 – Short-term	30–90 days	F-NET-004, F-NET-005, PH10-004, F-AD-001, F-DB-005	Application Engineering; API Platform; AD Team; Database Team	Apply strict CORS policy; migrate APIs behind production WSGI server and API gateway with authentication; remediate DOM-XSS via safe DOM sinks and CSP; disable anonymous SMB enumeration on PAYNOVA-DC; migrate customer password hashes from MD5 to Argon2id/bcrypt (transparent on-login upgrade).

P3 — Medium-term	90–180 days	F-NET-001, F-NET-003, F-NET-006, WEB-INFO-001	Application Engineering; Database Administrator; AD Team	Restrict LDAP RootDSE anonymous responses where deployment allows; remove sensitive paths from robots.txt; restrict administrative and backup paths at web-server layer; bind MySQL to internal interface and firewall to authorised sources; suppress Server header.
P4 — Continuous	Ongoing	F-NET-007	Configuration Management; Vulnerability Management	Enforce banner suppression and header hardening; maintain PCI-aligned patch cadence; upgrade out-of-support components (Samba 4.6.x — see R-022).

Appendix A. Evidence Register

‘Embedded’ evidence is reproduced inline in the section it supports (see Figure numbers).

‘Referenced’ evidence is held in the assessment working folder and cited by filename only.

‘Placeholder’ marks evidence that is expected but not yet received; the finding text describes what the screenshot will show once attached.

Evidence ID	Filename / reference	Type	Supports
EV-01	scope.md – PayNova Security Assessment Scope	Referenced	§1
EV-02	asset-inventory.md – PayNova Asset Inventory	Referenced	§2
EV-03	assessment-notes_md.docx	Referenced	§3–§5
EV-04	Network_Reconnaissance_Findings.txt	Referenced	§3
EV-05	AD-Reconnaissance.txt	Referenced	§4
EV-06	Network-testing-finings.md	Referenced	§5
EV-07	Web_Testing_Finding s.md	Referenced	§6.1
EV-08	Final_Acessment_Ch eck.txt (analyst working format)	Referenced	structural rework in v0.3
EV-09	paynova_customers _backup_2026-08-15.csv (496 bytes)	Referenced	PN-WEB-001 (downloaded artefact)
EV-10	nmap-results.txt	Referenced	§3
EV-11	PH7-001-tooolbox-network-interfaces.png	Referenced	§2.4

EV-12	PH7-002-tooolbox-IP-addresses.png	Referenced	§2.4
EV-13	PH7-003-TCP-Service-Validation.png	Referenced	§5
EV-14	PH8-001-nmap-paynova-portal.png	Embedded	§3.1.1
EV-15	PH8-002-nmap-webapp.png	Embedded	§3.1.2
EV-16	PH8-003-nmap-database.png	Embedded	§3.2.1
EV-17	PH8-004-cardscheme-nmap.png	Embedded	§3.2.2
EV-18	PH8-004-cardscheme-nmap-detail.png	Referenced	§3.2.2
EV-19	PH8-005-connectivity-dmz.png	Referenced	§3.1
EV-20	PH8-006-AD-port-validation.png	Embedded	§3.3.1
EV-21	PH8-006-connectivity-paymentnet.png	Referenced	§5
EV-22	PH8-007-LDAP-rootDSE.png	Embedded	§4
EV-23	PH8-007-LDAP-rootDSE-2.png	Embedded	§4
EV-24	PH8-008-SMB-OS-discovery.png	Embedded	§3.3.1
EV-25	PH8-009-full-network-discovery-1..22.png (22 files)	Referenced/Embedded	§3 (subset embedded)

EV-26	PH8-009-full-network-discovery-7.png	Embedded	§3.2.3
EV-27	PH8-009-full-network-discovery-9.png	Embedded	§3.2.1
EV-28	PH8-009-full-network-discovery-19.png	Embedded	§3.1.1
EV-29	PH9-001-Findings-Excessive-DMZ-to-Payment.png	Embedded	§5.1
EV-30	PH9-002-Findings-DMZ-to-Corporate_Network_Segmentation.png	Embedded	§5.2
EV-31	PH9-003-Findings-Payment-to-AD_Segmentation.png	Embedded	§5.3
EV-32	PH9-004-Findings-Toolbox_Network_Reachability.png	Embedded	§5.4
EV-33	PH10-001-Findings-Web-Testing.png	Embedded	§6.1
EV-34	PH10-002-Findings-Web-Testing.png	Embedded	§6.1
EV-35	PH10-XXX-Findings-SQLi-Login-Bypass-Request-Response.png	Placeholder	§6.2
EV-36	PH10-XXX-Findings-SQLi-Login-Bypass-Admin-Session.png	Placeholder	§6.2

EV-37	PHI0-003-Findings-IDOR-Unauthorized-Basket-Access.png	Placeholder	§6.3
EV-38	PHI0-XXX-Findings-Broken-Access-Control-Admin-Config.png	Placeholder	§6.4
EV-39	PHI0-004-Findings-DOM-XSS-Search-Parameter.png	Placeholder	§6.5
EV-40	FIND-008-Session-Token-Remains-Valid-After-Logout.png	Placeholder	§6.6
EV-41	PHI0-XXX-Findings-Server-Version-Disclosure.png	Placeholder	§6.7
EV-42	PHI1-XXX-Findings-API-Cards-Enumeration.png	Placeholder	§7.1
EV-43	PHI1-XXX-Findings-API-Debug-Config-Disclosure.png	Placeholder	§7.2
EV-44	PHI1-XXX-Findings-API-Backup-File-Test-Negative.png	Placeholder	§9.1
EV-45	PHI1-XXX-Findings-API-Command-Injection-SourceReview-Negative.png	Placeholder	§9.2
EV-46	PHI1-XXX-Findings-API-Stack-Trace-Test-Negative.png	Placeholder	§9.3

EV-47	LDAP-Anonymous-Access-Validation.png	Placeholder	§4.2.1
EV-48	SMB-Anonymous-Enumeration.png	Placeholder	§4.2.2
EV-49	AD-Password-Policy-Enumeration.png	Placeholder	§4.2.3
EV-50	SMB-Anonymous-Share-Access-Denied.png	Placeholder	§4.3 (P-AD-002)
EV-51	MySQL-Root-Remote-Access-Grants.png	Placeholder	§8.1 (F-DB-001)
EV-52	DB-Cards-Table-Schema-and-Masked-Sample.png	Placeholder	§8.2 (F-DB-002)
EV-53	DB-Customers-Table-PII.png	Placeholder	§8.3 (F-DB-003)
EV-54	DB-Application-Account-Grants.png	Placeholder	§8.4 (F-DB-004)
EV-55	DB-Password-Hash-Length-Verification.png	Placeholder	§8.5 (F-DB-005)

Appendix B. Tools Used

Tool	Version	Purpose in this iteration
Nmap	7.93	Host discovery, TCP service/version enumeration, NSE scripts (http-robots.txt, ldap-rootdse, smb2-security-mode, mysql-info, smb-os-discovery).
netcat (BusyBox)	n/a	Namespace-pinned TCP reachability testing via

		'docker run --rm --network container:... busybox nc -zvw 3'.
curl	n/a	Direct HTTP requests to API endpoints for enumeration and testing.
Docker CLI	n/a	Container and network inspection; namespace-pinning for segmentation tests.
Windows PowerShell	n/a	Wrapper for docker exec commands.
Web browser (Edge)	n/a	Web-tier reconnaissance; direct GET requests to disclosed paths; XSS proof-of-concept.
Burp Suite (Community/Pro)	n/a	Request capture, Repeater for authorisation and injection testing (basket BOLA, SQLi auth bypass, admin config, session-token replay).

Appendix C. Redaction Note

This document includes evidence from a simulated laboratory. In a live engagement the following redaction practice should be applied before distribution: (a) card numbers (PAN) masked to first-6/last-4; (b) CVV values fully redacted; (c) wallet PINs fully redacted; (d) JWT signing secrets fully redacted; (e) authentication tokens observed during testing fully redacted; (f) SQL-injection payloads that produce reliable authentication bypass may be summarised rather than reproduced verbatim, with the exact payload retained in the analyst evidence pack. Unredacted evidence should be retained in an access-controlled evidence pack, separate from the report body, and shared only under NDA.

Appendix D. Project Deliverables Index

This report is part of an integrated set of deliverables produced during the PayNova capstone engagement. Cross-references throughout this document use the identifiers below.

Deliverable	Version	Date	Purpose	Cross-references from this report
PayNova Cybersecurity Assessment Report	v1.0 (this document)	27 Sep 2026	Consolidated findings from network, AD/IAM, web-app, API, and database testing.	Primary technical narrative; source for all F-NET-*, F-AD-*, F-DB-*, PN-WEB-*, WEB-*, PH10-*, FIND-*, PAYNOVA-* IDs used across the deliverables.
PayNova Risk Register	v5	27 Sep 2026	Risk register consolidating technical, governance, and privacy findings.	45 tracked risks (R-001 to R-045). Every finding in this report has a corresponding register entry. Governance risks R-021 to R-034 added in v2; privacy governance risks R-035 to R-040 added in v3; AD/DB risks R-041 to R-045 added in v5 alongside the F-

				NET-001 revision and R-017 re-scoring.
PayNova Privacy Impact Assessment	v1.2	27 Sep 2026	DPIA covering NDPA 2023, GDPR, and UK GDPR – updated to reflect DB-tier confirmation of cleartext PII storage.	15 privacy risks (PR-01 to PR-15). Several cross-reference this report's technical findings, including the newly-confirmed database findings.
PayNova Incident Response Plan	v1.2	27 Sep 2026	Incident-handling framework with PN-WEB-001 as the worked example.	The Remediation Roadmap (§12) references the IRP for coordinated breach response. Every SEV-1 example in the IRP is a finding from this report.
PayNova Executive Briefing	final	27 Sep 2026	13-slide non-technical briefing for the executive panel.	Summarises the four Critical findings in plain language; presents the 6-month roadmap.

D.1 Reading Order

For an executive audience: read the Executive Summary of this report, then the PIA Executive Summary, then the IRP §1 (Purpose & Scope) and §3 (Severity Classification). For a technical

audience: read this report in full, then the Risk Register for the tracked-remediation view. For a compliance / audit audience: read this report's §10 (Compliance Mapping), then the PIA in full, then the Risk Register filtered by regulatory framework. For an incident-response audience: read the IRP in full, then this report's §6 (PN-WEB-001) and §7 (API findings) for context on the worked example.

D.2 Update Cycle

This report and the Risk Register are treated as living documents and will iterate as further assessment evidence is received (see §Version History). The PIA is reviewed at least annually and on any material change to processing. The IRP is reviewed at least annually and after any SEV-1 or SEV-2 incident. Where a change to any one document affects another (for example, a new finding in this report that introduces a new privacy risk), the corresponding document is updated in the same change window.